

《360度介绍网联汽车安全》

李均 (Selfighter), 360 Unicorn Team

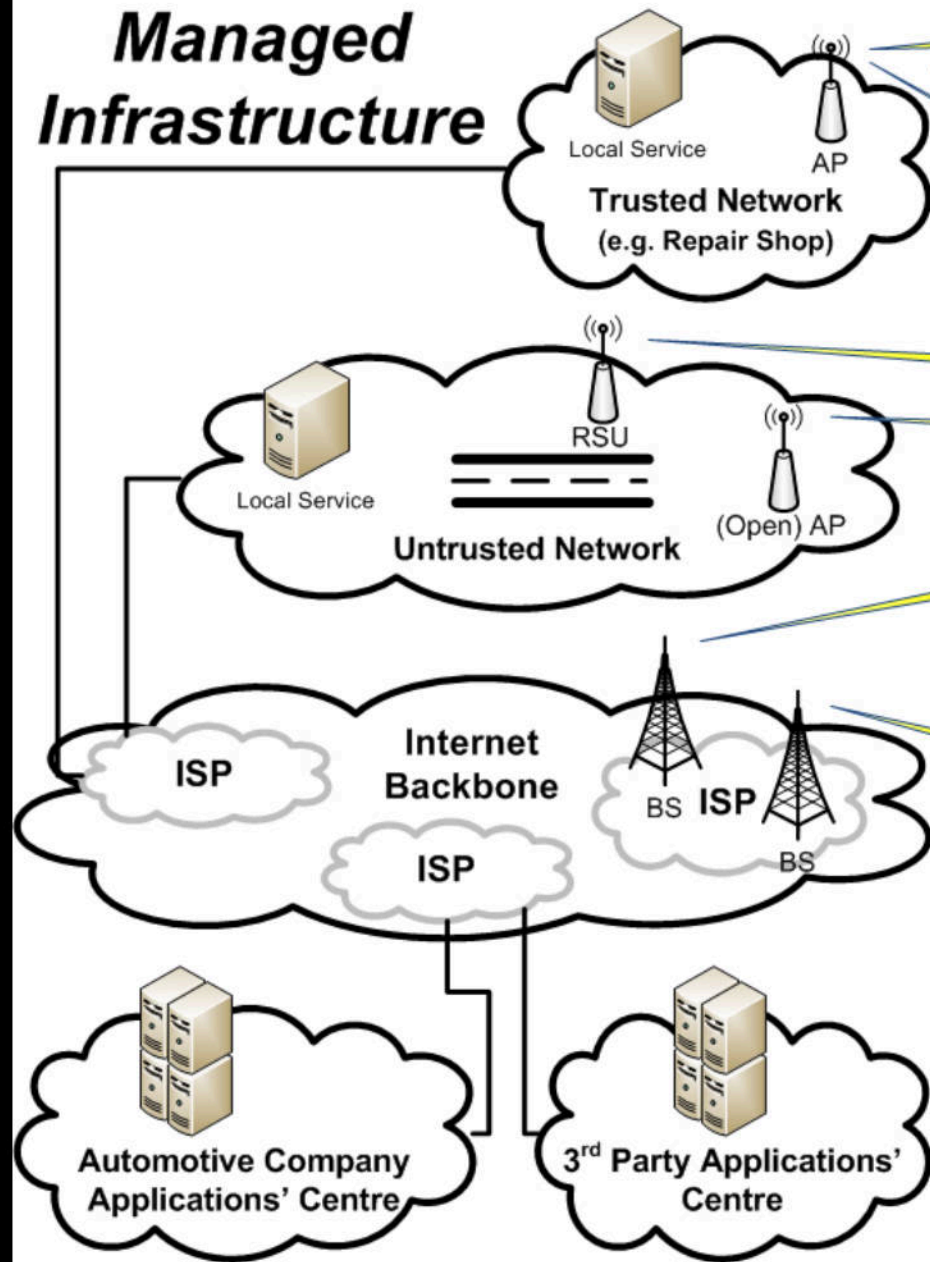


Who Am I ?

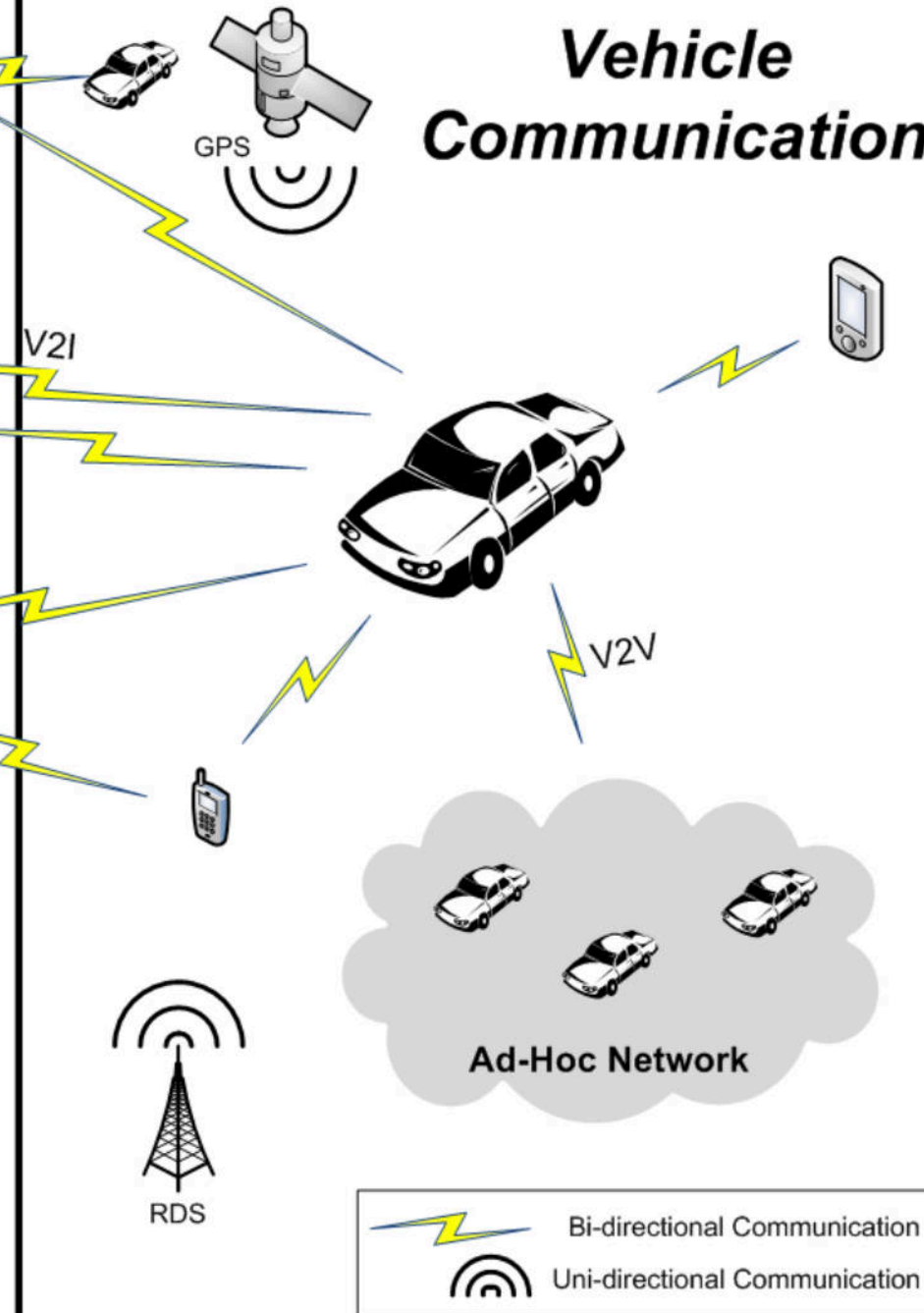


李均(ID: selfighter, 奇虎360公司独角兽团队安全研究员, 中国首个DEFCON GROUP DC010发起者, DEFCON GROUPs Review Board 中国区成员, 360无线电安全研究部安全研究员, 《无线电攻防大揭秘》、《智能汽车安全攻防大揭秘》作者, Blackhat&DEFCON、HITB、CanSecWest、KCon、Syscan360等安全峰会演讲者。DEFCON GROUPs Review Board 成员。

Managed Infrastructure



Vehicle Communication





Adaptive
Cruise Control

GPS SPOOFING

Low-cost GPS simulator

HUANG Lin, YANG Qing
Unicorn Team – Radio and Hardware Security Research
Qihoo 360 Technology Co. Ltd.

- Long-Range Radar
- LIDAR
- Camera
- Short-/Medium-Range Radar
- Ultrasound/Ultra-Short-Range Radar

)]. All of
LiDAR) to
on and de-
g. Indeed,
he mission
amera are
esentation



摄像头（计算机视觉）

Robust Physical-World Attacks on Deep Learning Models

Visit <https://iotsecurity.eecs.umich.edu/#roadsigns> for an FAQ

Ivan Evtimov³, Kevin Eykholt², Earlene Fernandes³, Tadavoshi Kohno³,
Bo Li¹, Atul Prakash², Amir Rahmati⁴, and Dawn Song^{*1}

¹University of California, Berkeley

²University of Michigan Ann Arbor

³University of Washington

⁴Stony Brook University

Abstract—Although deep neural networks (DNNs) perform well in a variety of applications, they are vulnerable to adversarial examples resulting from small-magnitude perturbations added to the input data. Inputs modified in this way can be mislabeled as a target class in targeted attacks or as a random class different from the ground truth in untargeted attacks. However, recent studies have demonstrated that such adversarial examples have limited effectiveness in the physical world due to changing physical conditions—they either completely fail to cause misclassification or only work in restricted cases where a relatively complex image is perturbed and printed on paper. In this paper, we propose a general attack algorithm—Robust Physical Perturbations (RP₂)—that takes into account the numerous physical conditions and produces robust adversarial perturbations. Using a real-world example of road sign recognition, we show that adversarial examples generated using RP₂ achieve high attack success rates in the physical world under a variety of conditions, including different viewpoints. Furthermore, to the best of our knowledge, there is currently no standardized way to evaluate physical adversarial perturbations. Therefore, we propose a two-stage evaluation methodology and tailor it to the road sign recognition use case. Our methodology captures a range of diverse physical conditions, including those encountered when images are captured from moving vehicles. We evaluate our physical attacks using this methodology and effectively fool two road sign classifiers. Using a perturbation in the shape of black and white stickers, we attack a real Stop sign, causing targeted misclassification in 100% of the images obtained in controlled lab settings and above 84% of the captured video frames obtained on a moving vehicle for one of the classifiers we attack.

Although there is significant progress in creating digital adversarial perturbations, *e.g.*, by modifying an image representing a real-world scene that a cyber-physical system might perceive [7], [9], a fundamental open question, which we answer in this paper, is whether it is possible to create *robust physical adversarial perturbations*—small modifications to real-world objects themselves that can trigger misclassifications in a DNN under widely varying physical conditions.

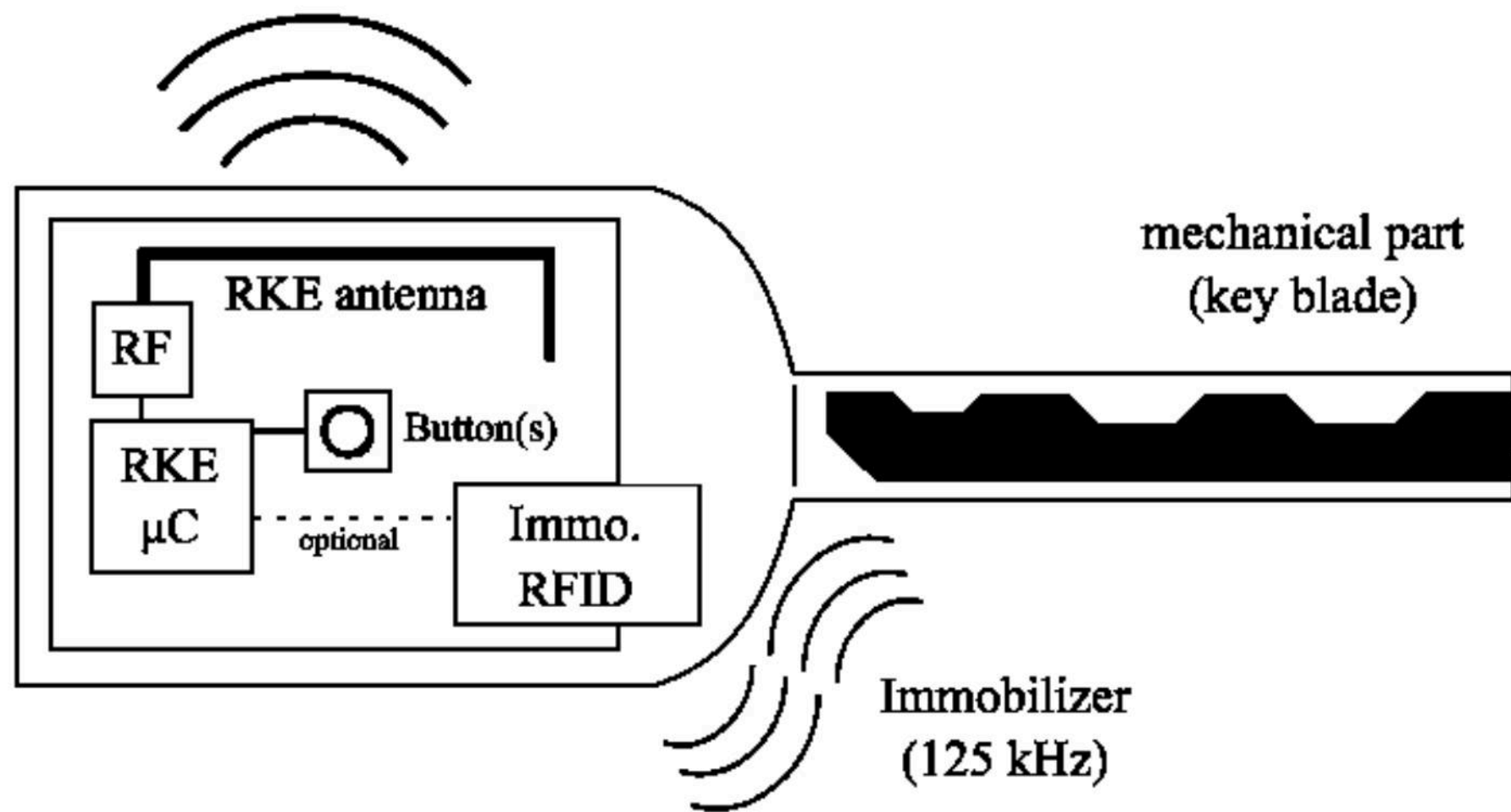
We identify several challenges that must be overcome in order for an effective physical adversarial perturbation to be created: (1) A perturbation should be constrained to the targeted object and cannot be added to the object's background because that can vary. Many digital adversarial example generation algorithms do not consider this constraint (*i.e.*, they add perturbations to the entire area of a digital image, which includes both the targeted object and its background). (2) A perturbation should be robust against various dynamic physical conditions that can potentially decrease its effectiveness. For instance in recognition systems, the generated physical adversarial example should be robust against different viewing conditions. (3) A perturbation in the digital world can be so low in magnitude that humans cannot perceive them. But, such small magnitude perturbations may not be captured by real world sensors due to sensor imperfections, and more generally, physical limitations of the sensor technology. (4) A perturbation should account for imperfections in the fabrication process. Printers, for example, cannot generate the entire color spectrum [26]. Therefore, it



通过微小修改来欺骗自动驾驶汽车
(图中Stop标识会被识别为40迈限速标识
， 图片来自网络)

Remote Keyless Entry System

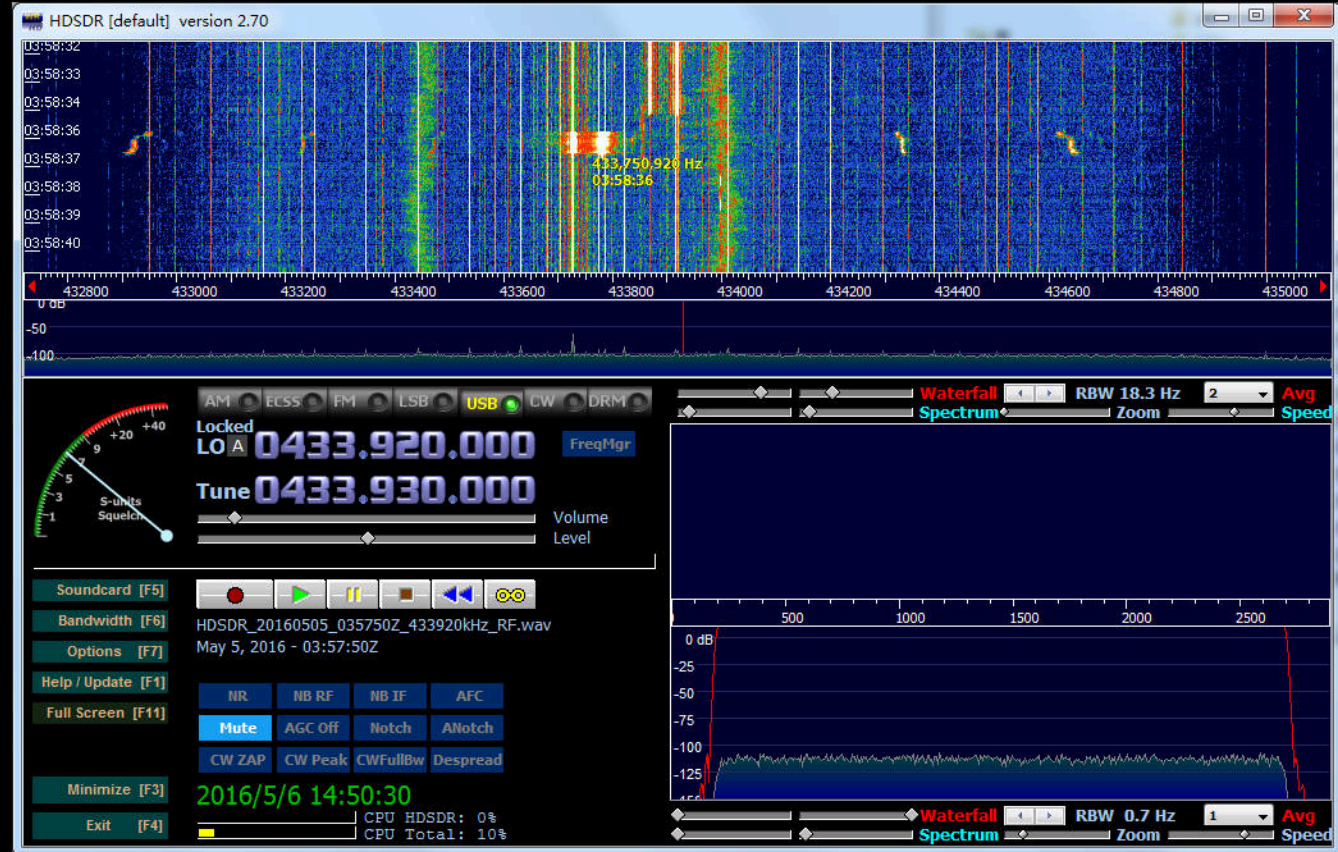
Remote keyless entry
(433/315/868 MHz)



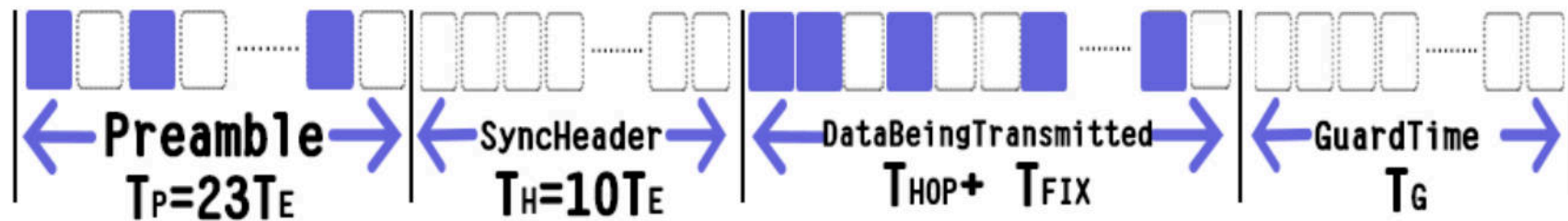
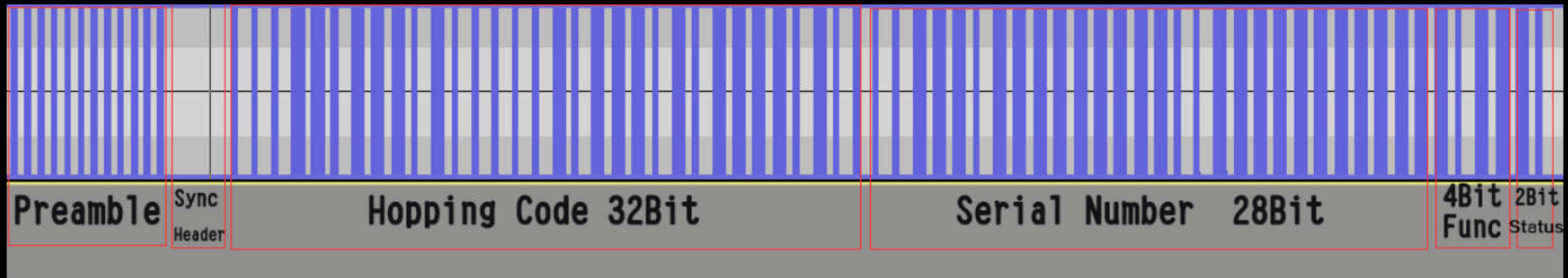
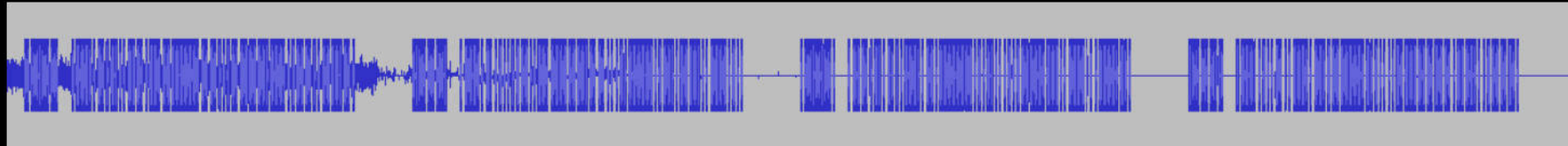


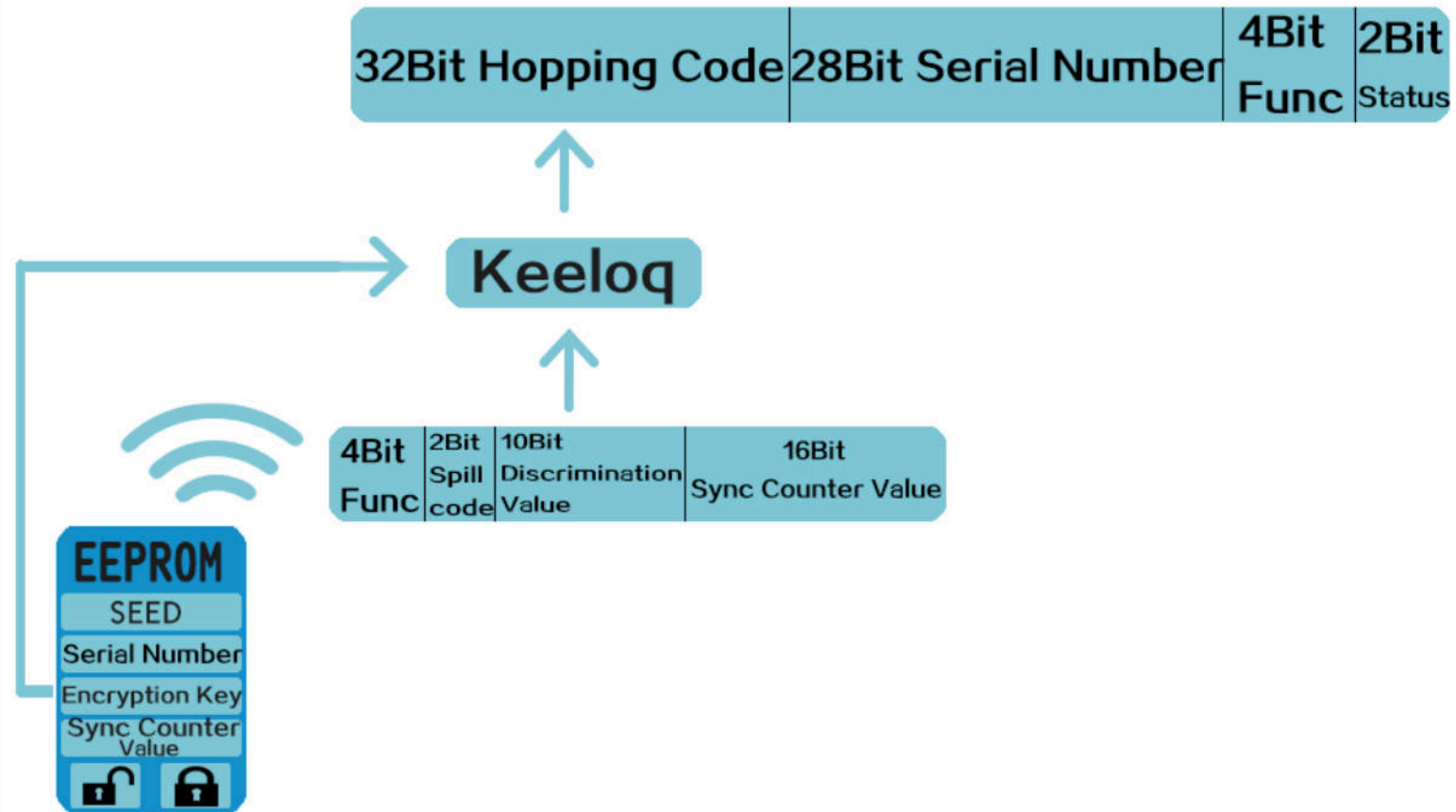


How to find the operating frequency



Analyse the wave





How to handle the value from key fob

```
ETemp = Hop - EHop;           // subtract last value from new one

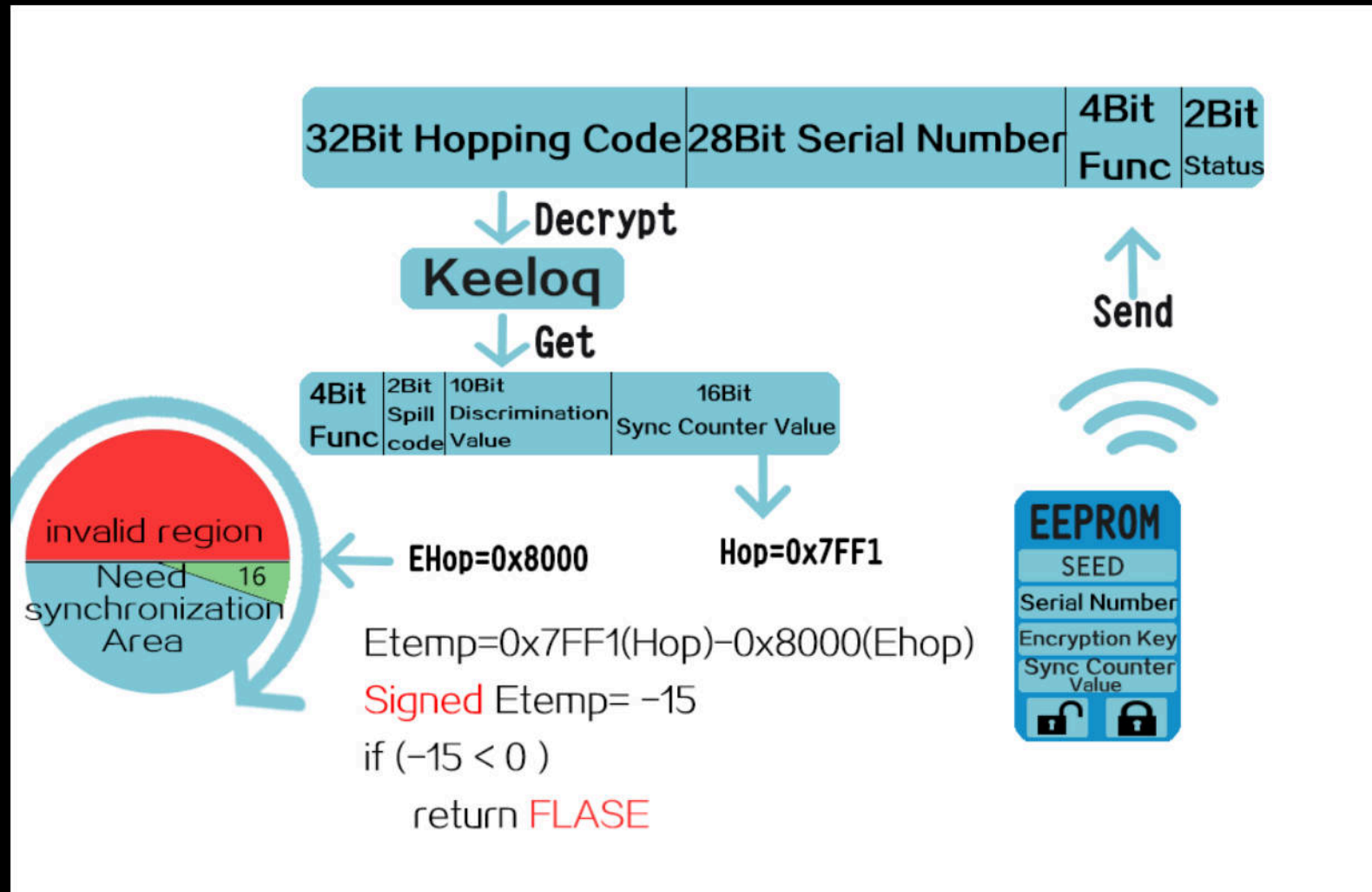
if ( ETemp < 0)                // locked region
    return FALSE;              // fail

else if ( ETemp > 16)          // resync region
    return ReqResync();

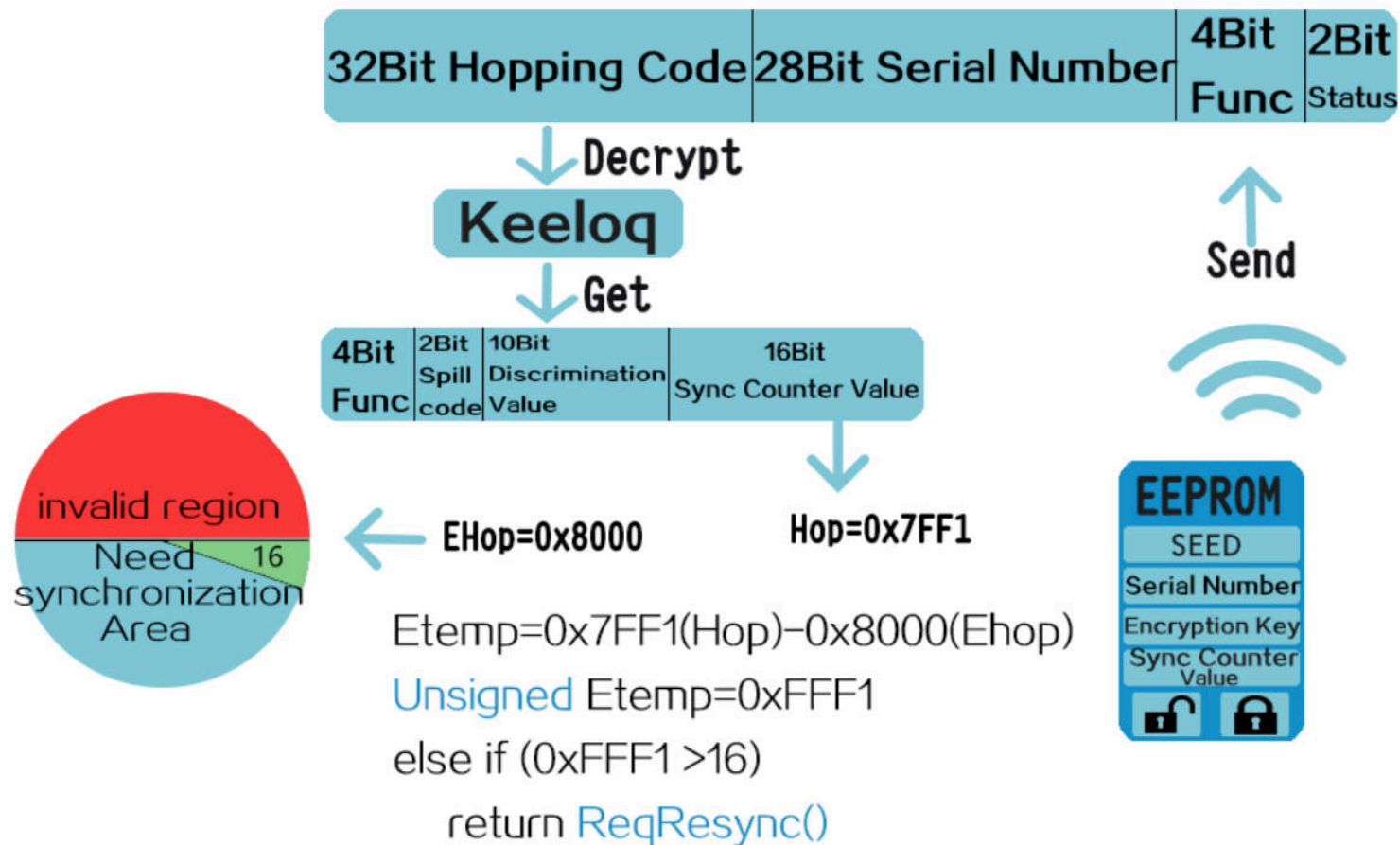
else                           // 0 >= ETemp > 16 ; open window
{
    if ( ETemp == 0)           // same code (ETemp == 0)
        FSame = TRUE;         // rise a flag

    FHopOK = TRUE;
    return TRUE;
}
} // HopCHK
```

How to handle the value from key fob



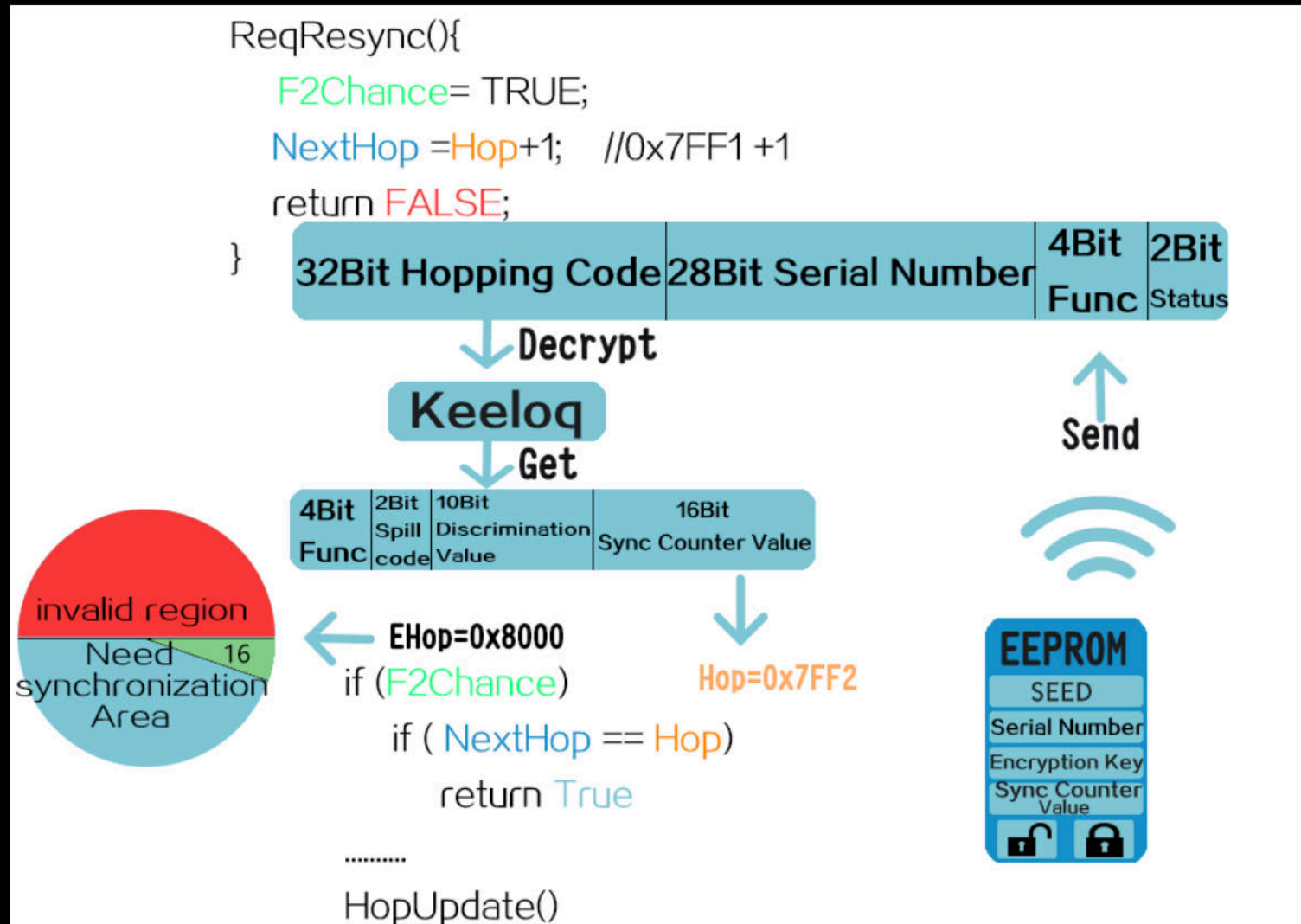
If the value is unsigned



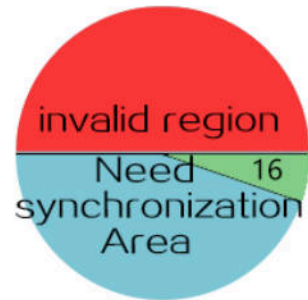
If the value is unsigned

```
byte ReqResync()  
{  
    F2Chance= TRUE;           // flag that a second (sequential) transmission  
    NextHop = Hop+1;          // is needed to resynchronize receiver  
    return FALSE;             // cannot accept for now  
}  
  
byte HopCHK()  
{  
    if ( F2Chance)  
        if ( NextHop == Hop)  
        {  
            F2Chance = FALSE;           // resync success  
            FHopOK = TRUE;  
            return TRUE;  
        }  
}
```

If the value is unsigned



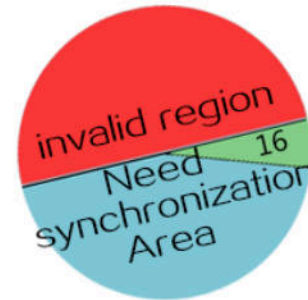
If the value is unsigned



← 0x8000

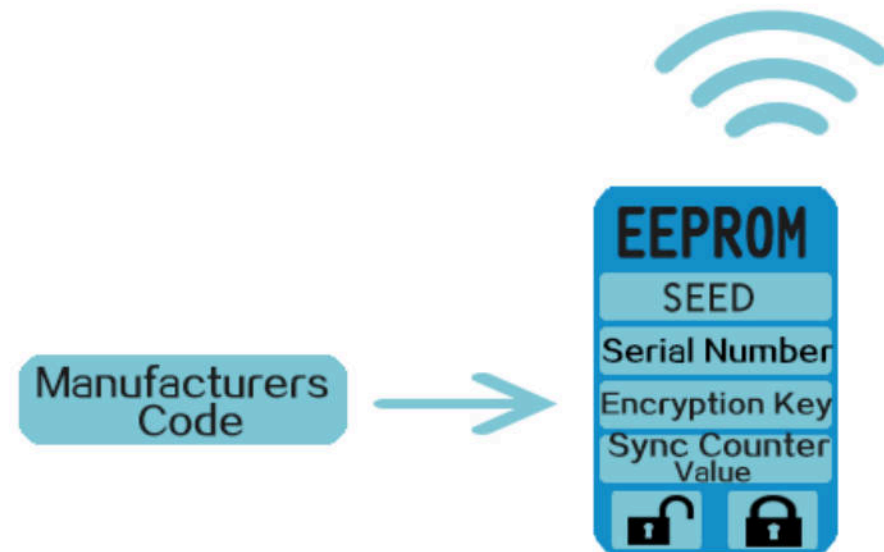
```
if (F2Chance)
    if (NextHop == Hop)
        return True
```

HopUpdate(NextHop)

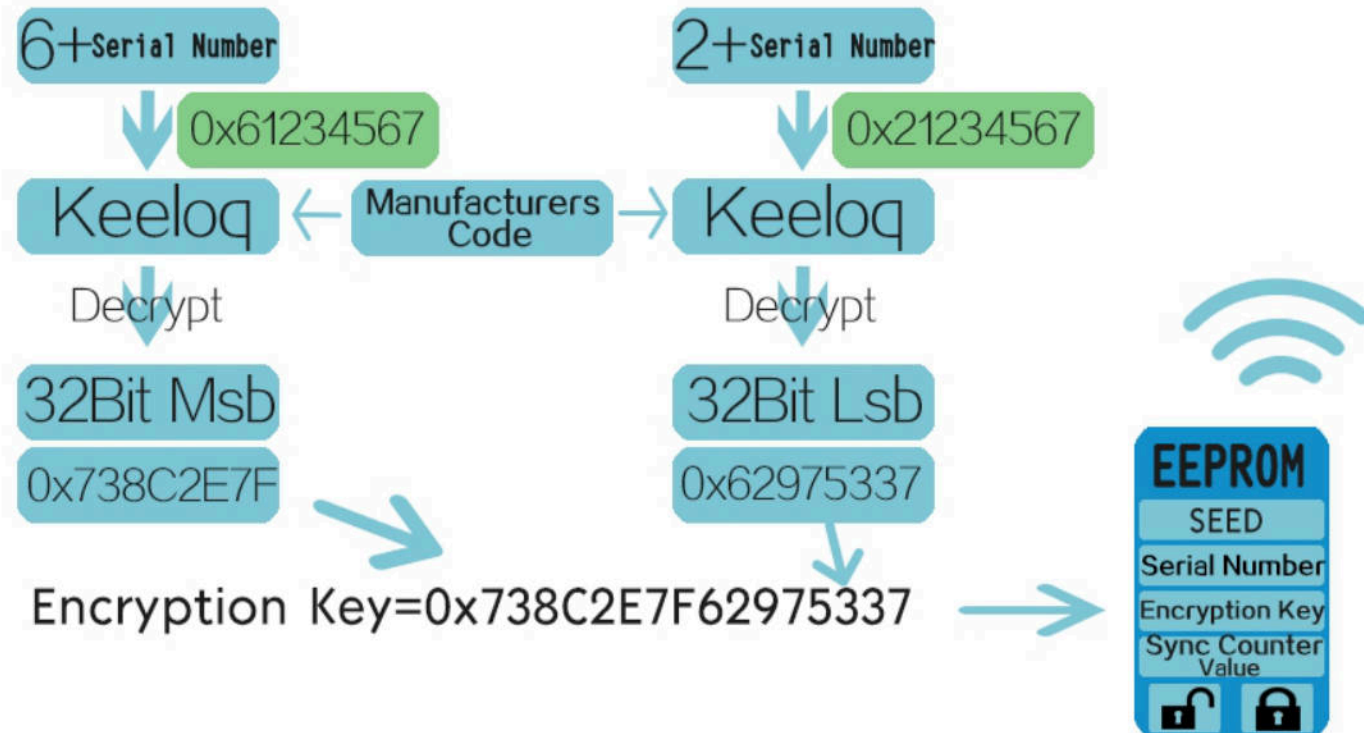


← 0x7FF2

Simple Encryption



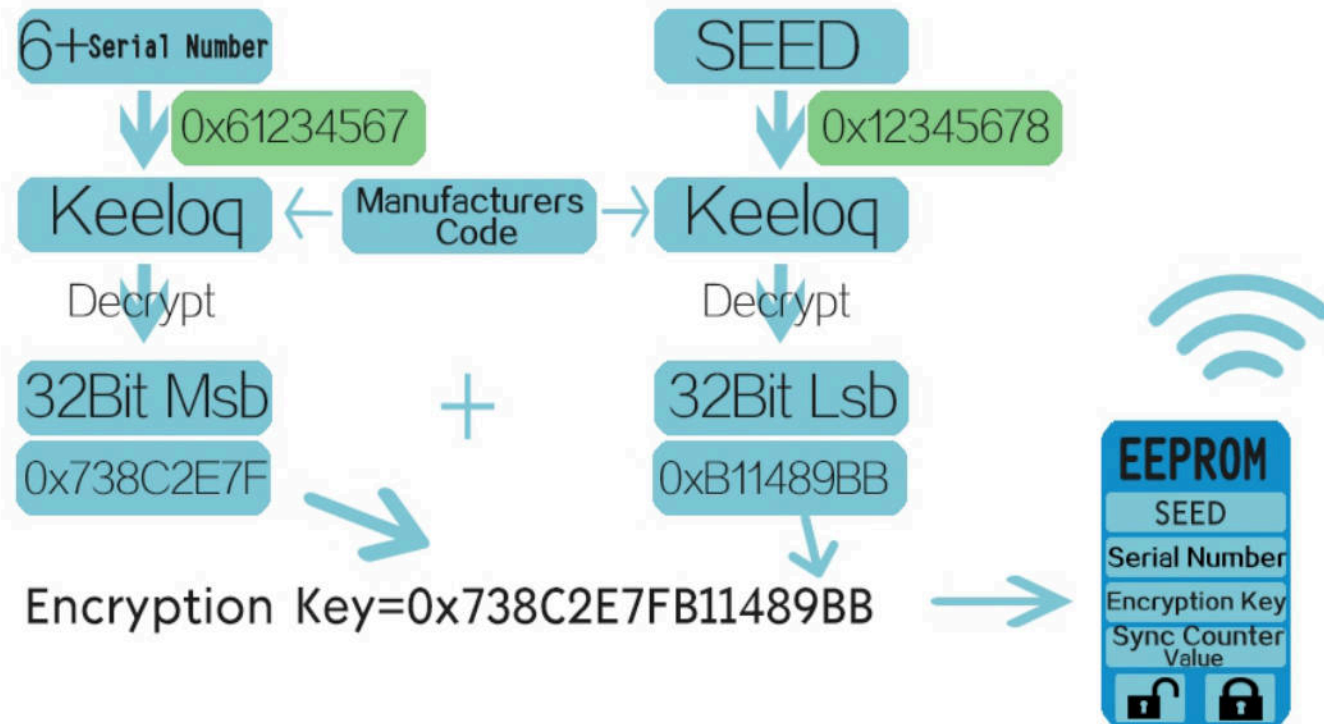
Serial.Number=0x1234567



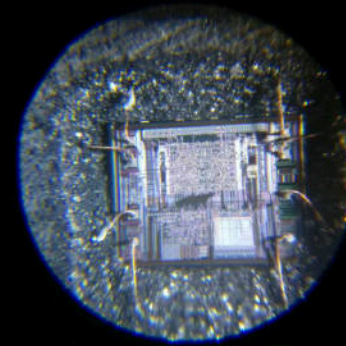
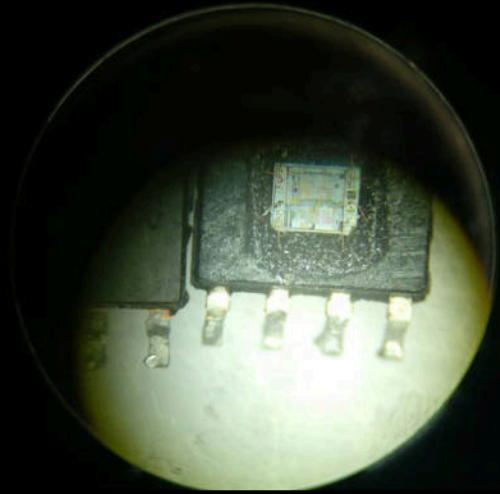
Secure Encryption

SEED=0x12345678

Serial.Number=0x1234567



Encryption Key is the problem



Car Passive Keyless Entry System

Car Passive Keyless Entry System

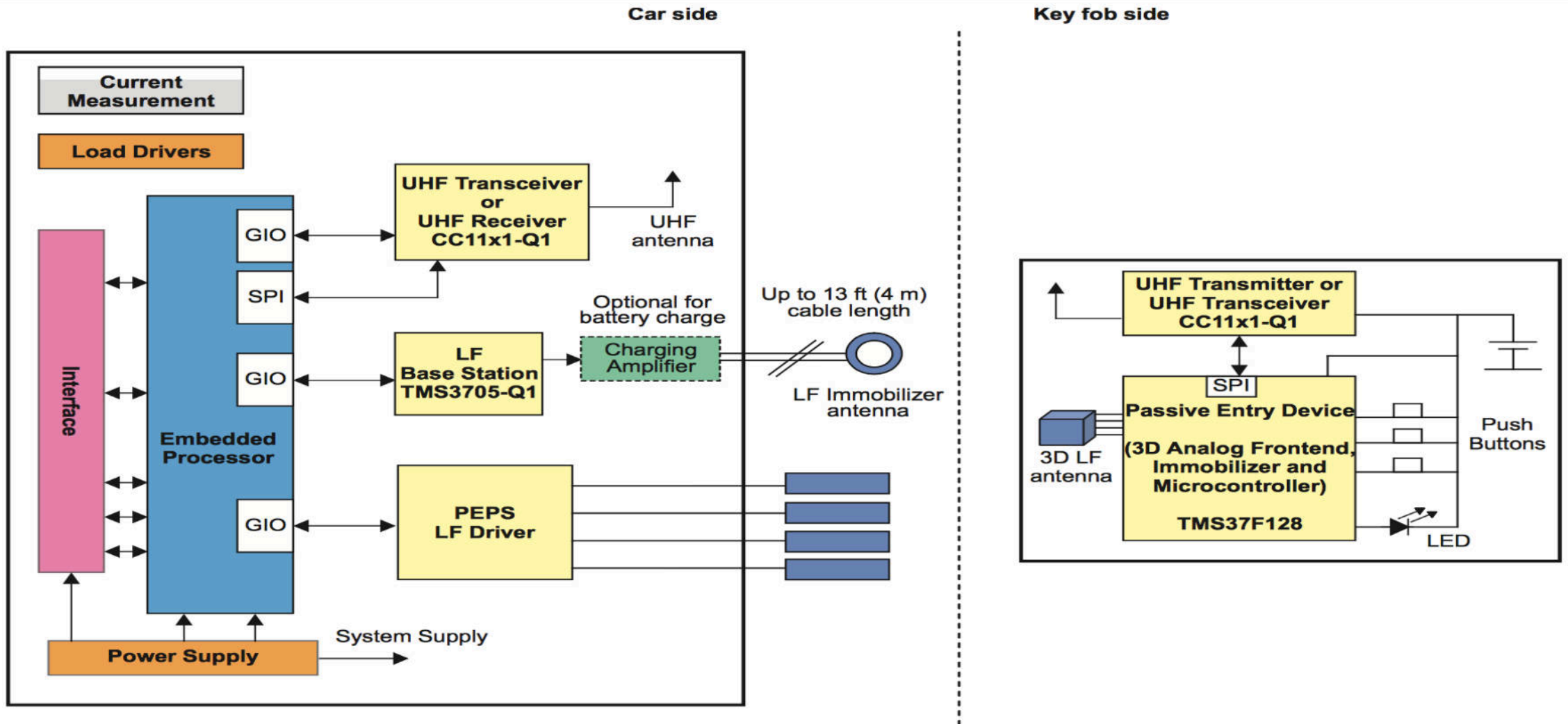
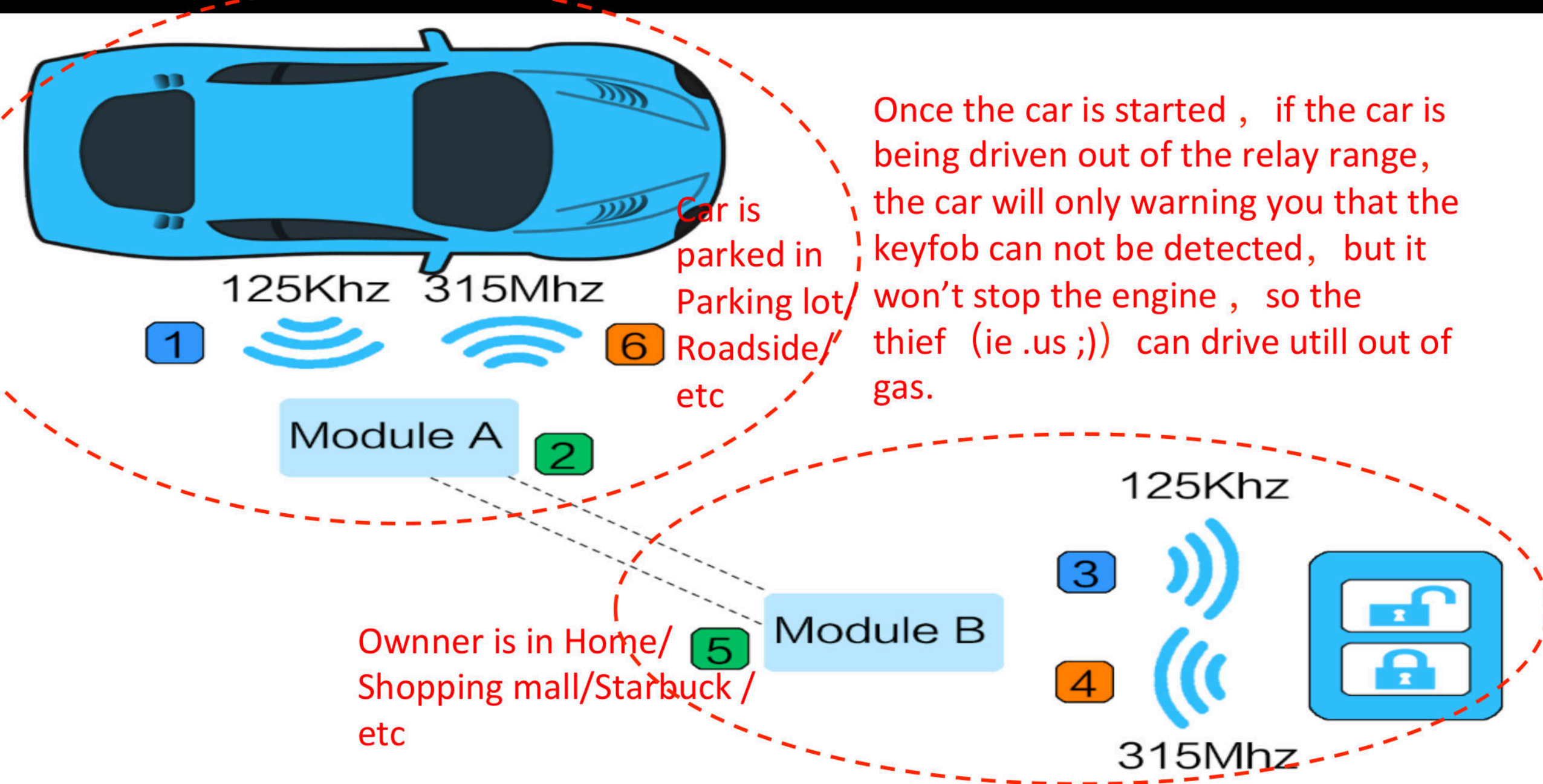


Figure 1. Application Diagram

Real world Attack scenarios







ENCHANTE CAFE

芳香邸
ENCHANTE

CAFE

D-PARK
A
中央大庁
Central Hall
B
通工部
Tsukuba
Engineering
Department

TOKYO
CHAOS

Remote physical control

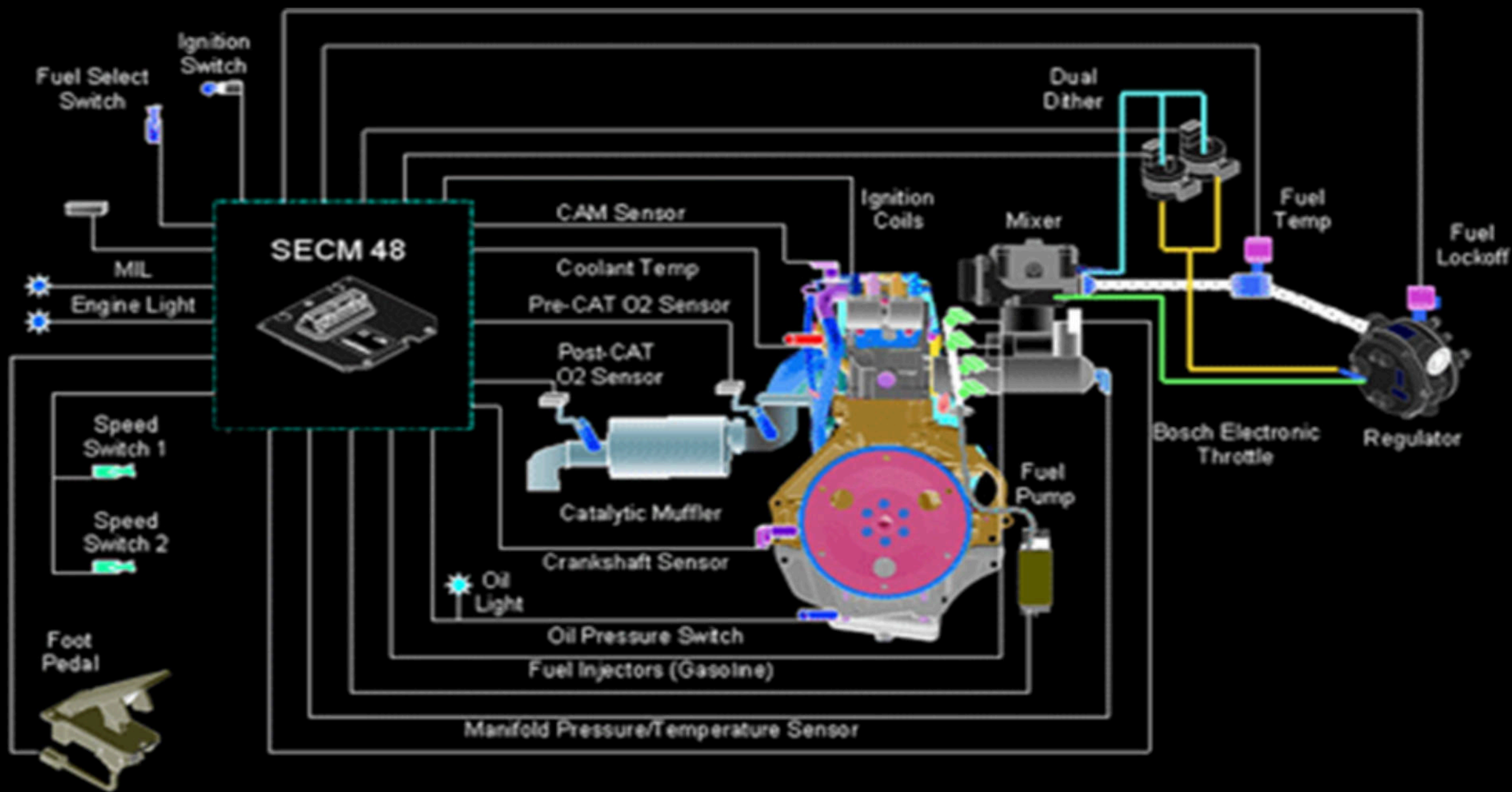
ECU (Electronic Control Unit) 简介

In automotive electronics, **Electronic Control Unit (ECU)** is a generic term for any secret system that controls one or more of the electrical system or subsystems in a transport vehicle

Types of ECU include Electronic/engine Control Module (ECM), Powertrain Control Module (PCM), Transmission Control Module (TCM), Brake Control Module (BCM or EBCM), Central Control Module (CCM), Central Timing Module (CTM), General Electronic Module (GEM), Body Control Module (BCM), Suspension Control Module (SCM), control unit, or control module

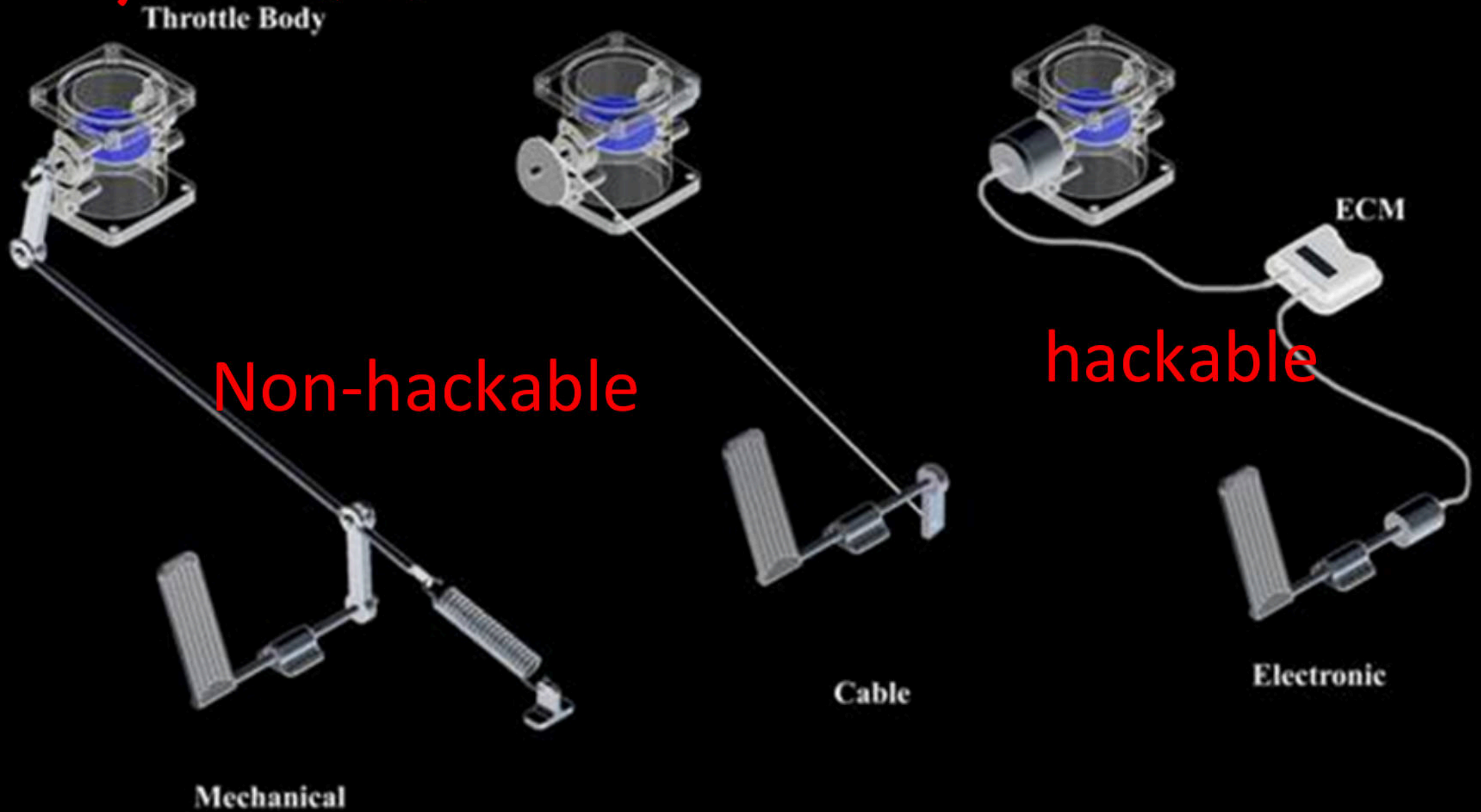


电子控制单元例子



Drive-by-wire 系统

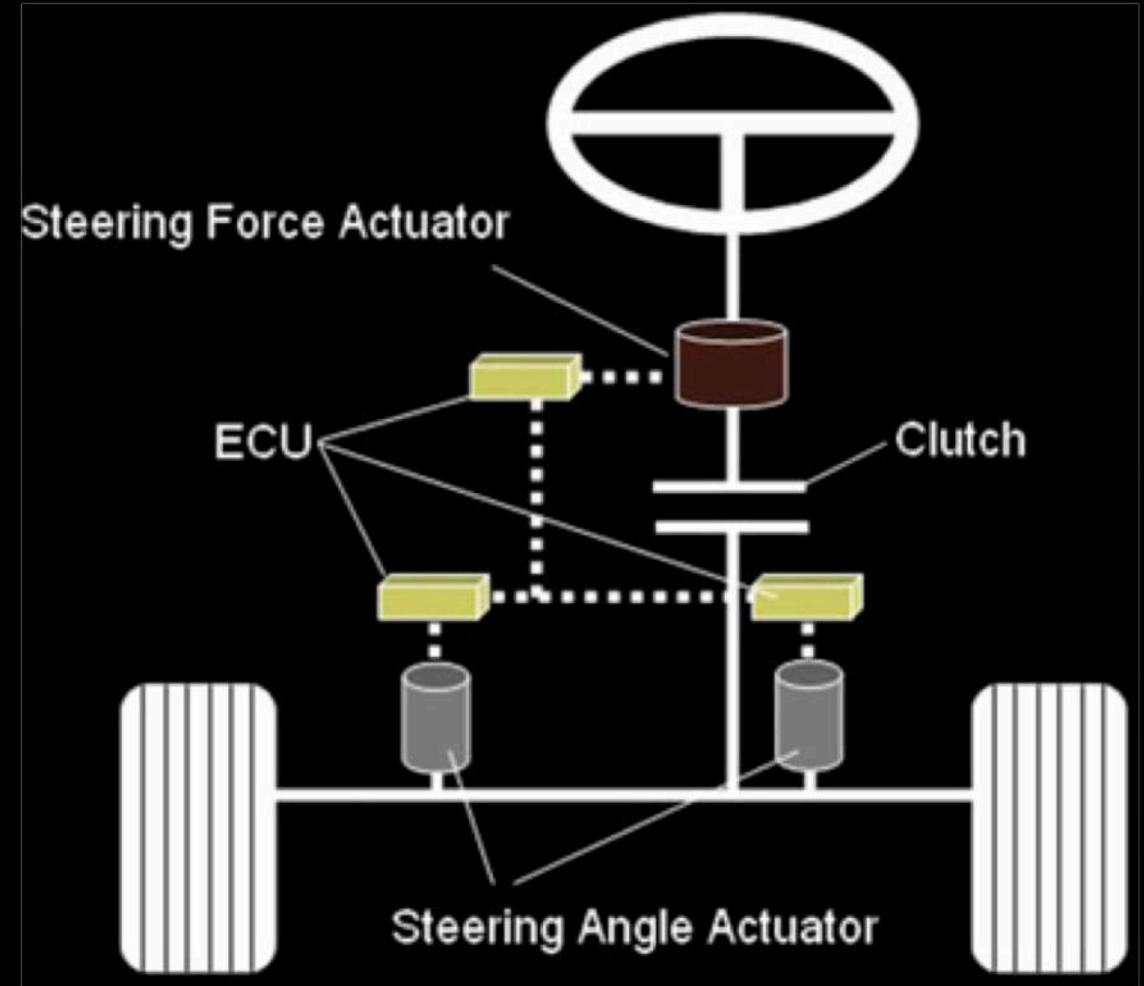
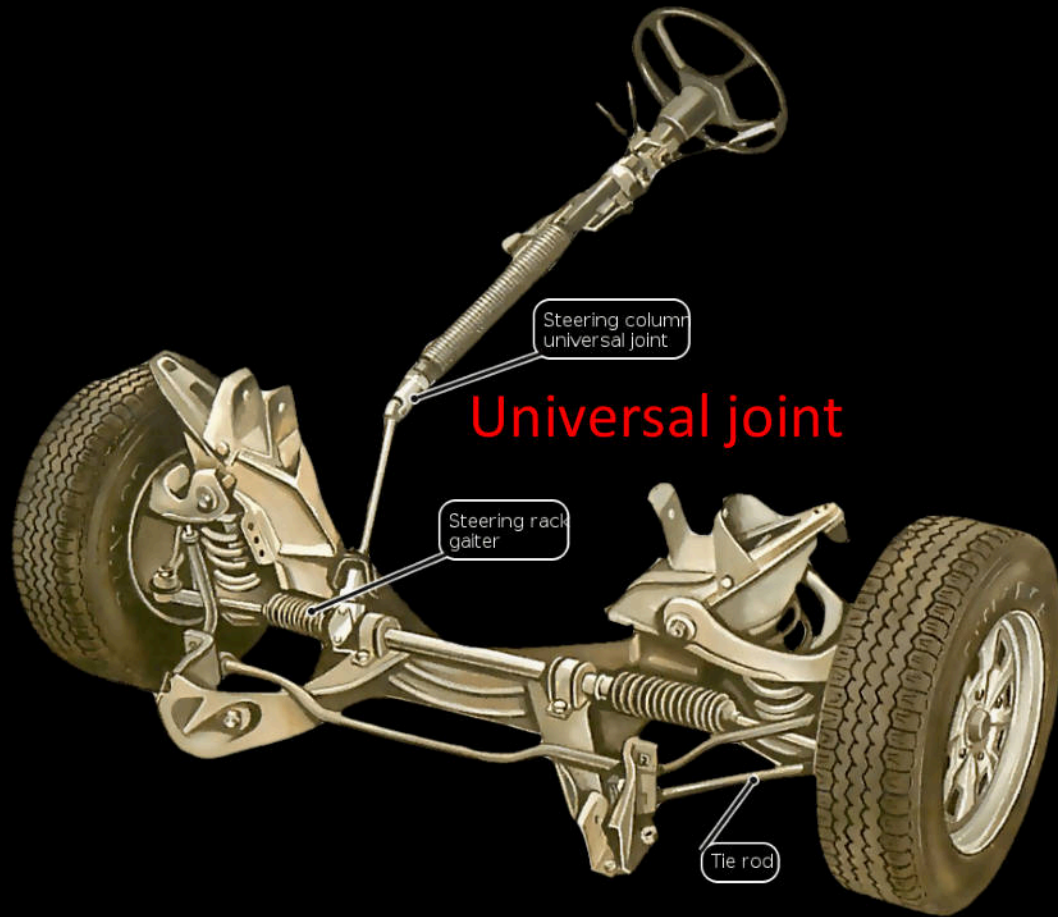
32



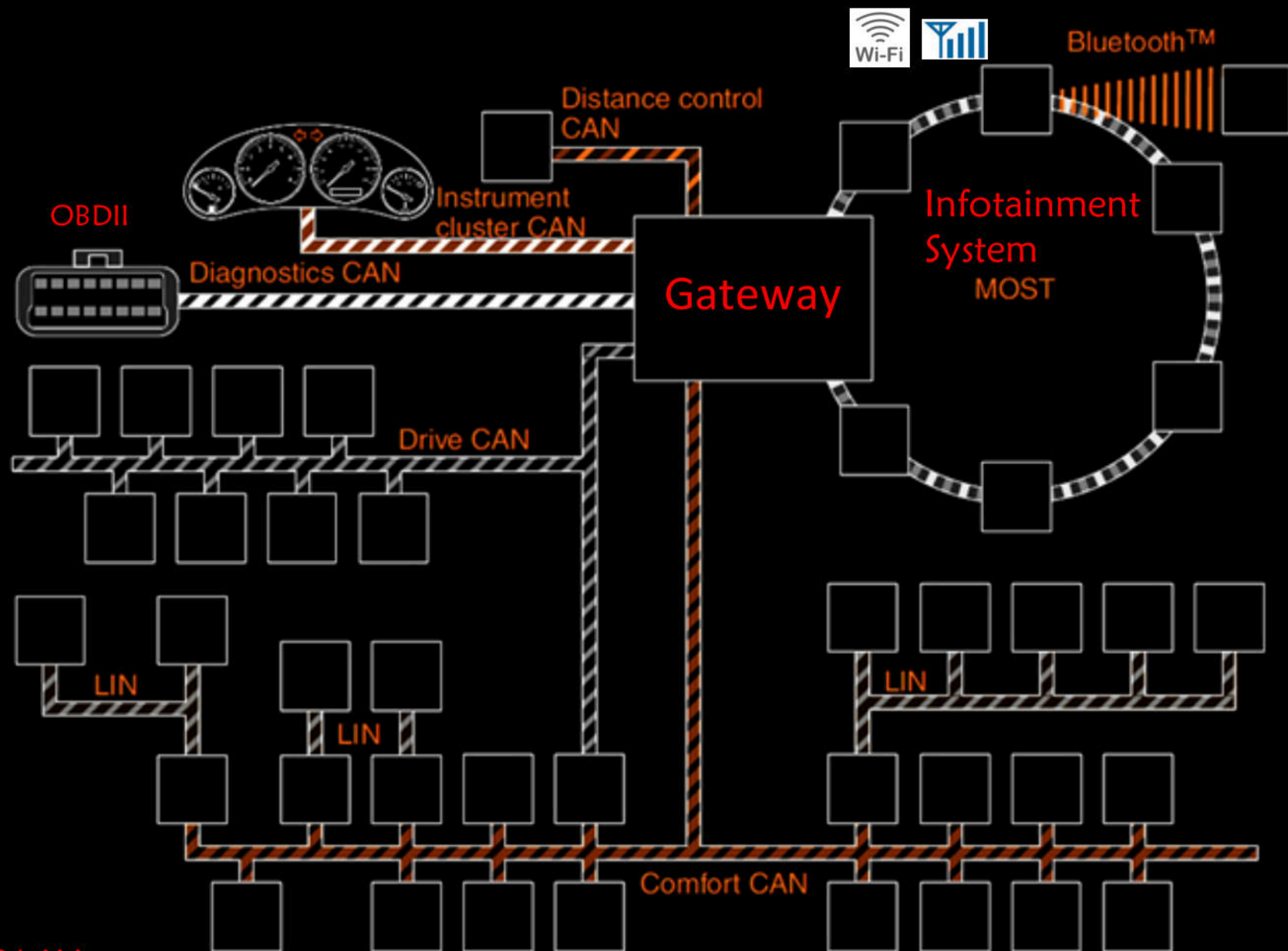
Steering-by-wire system

33

Steer-by-wire
(with mechanical fallback clutch)

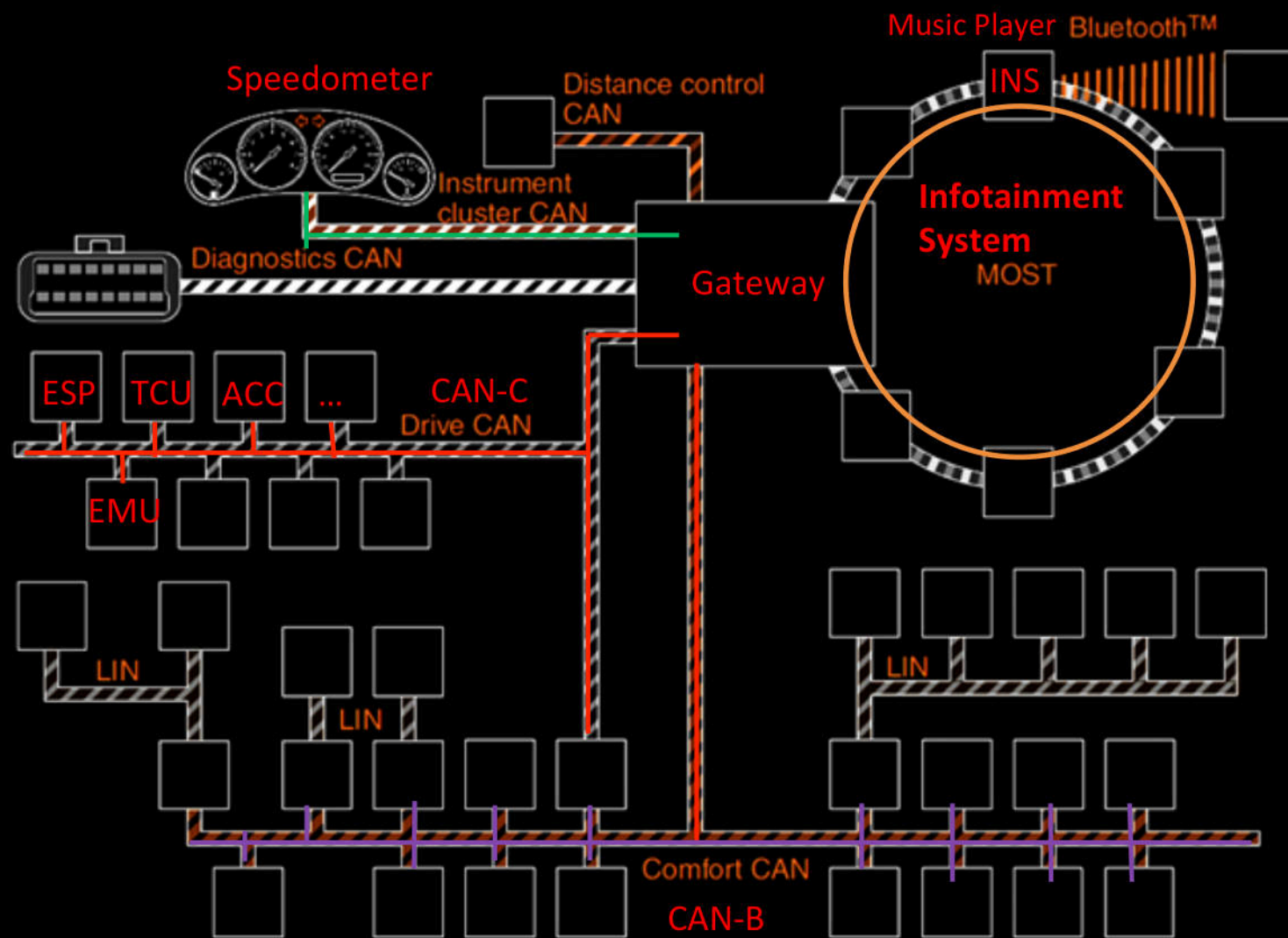


汽车网络架构



MOST
LIN
CAN
FlexRay
Bluetooth
Wifi
SubGHz

汽车通信举例



ESP (电子稳定系统)
EMU (发动机控制器)
TCU (变速器控制器)
ACC (自适应巡航)
INS (惯性导航)

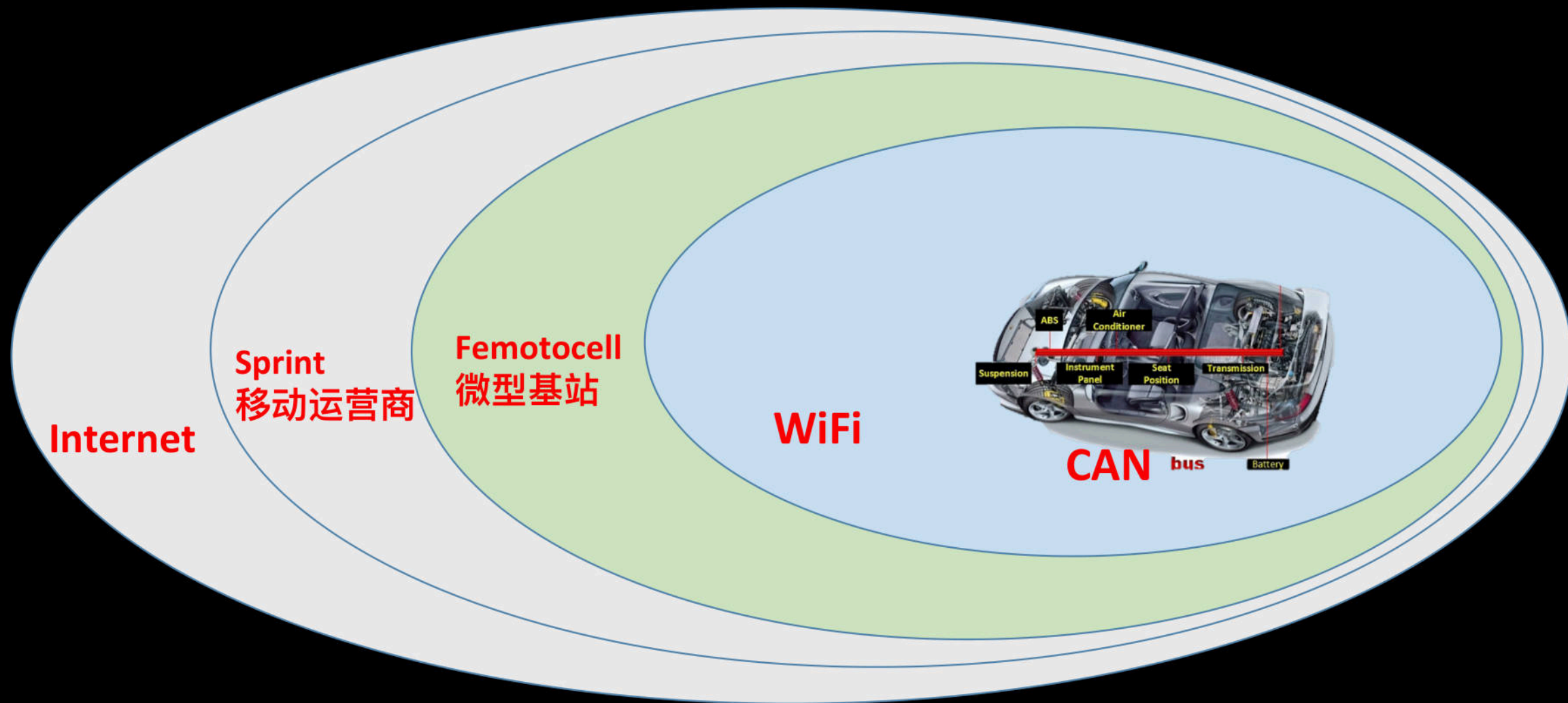
Seat Controller

17/11/27 10:24 AM

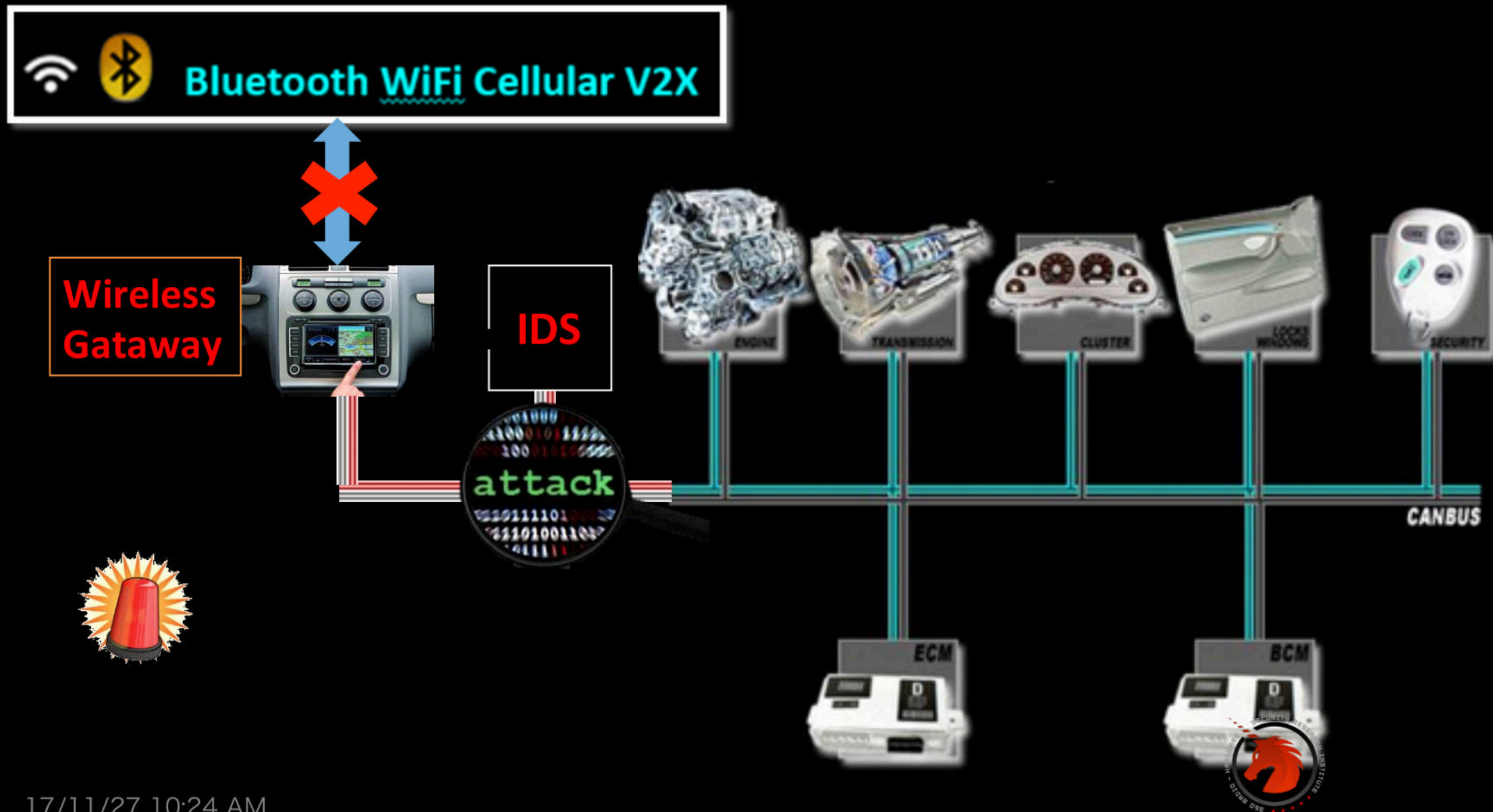


远程物理攻击案例

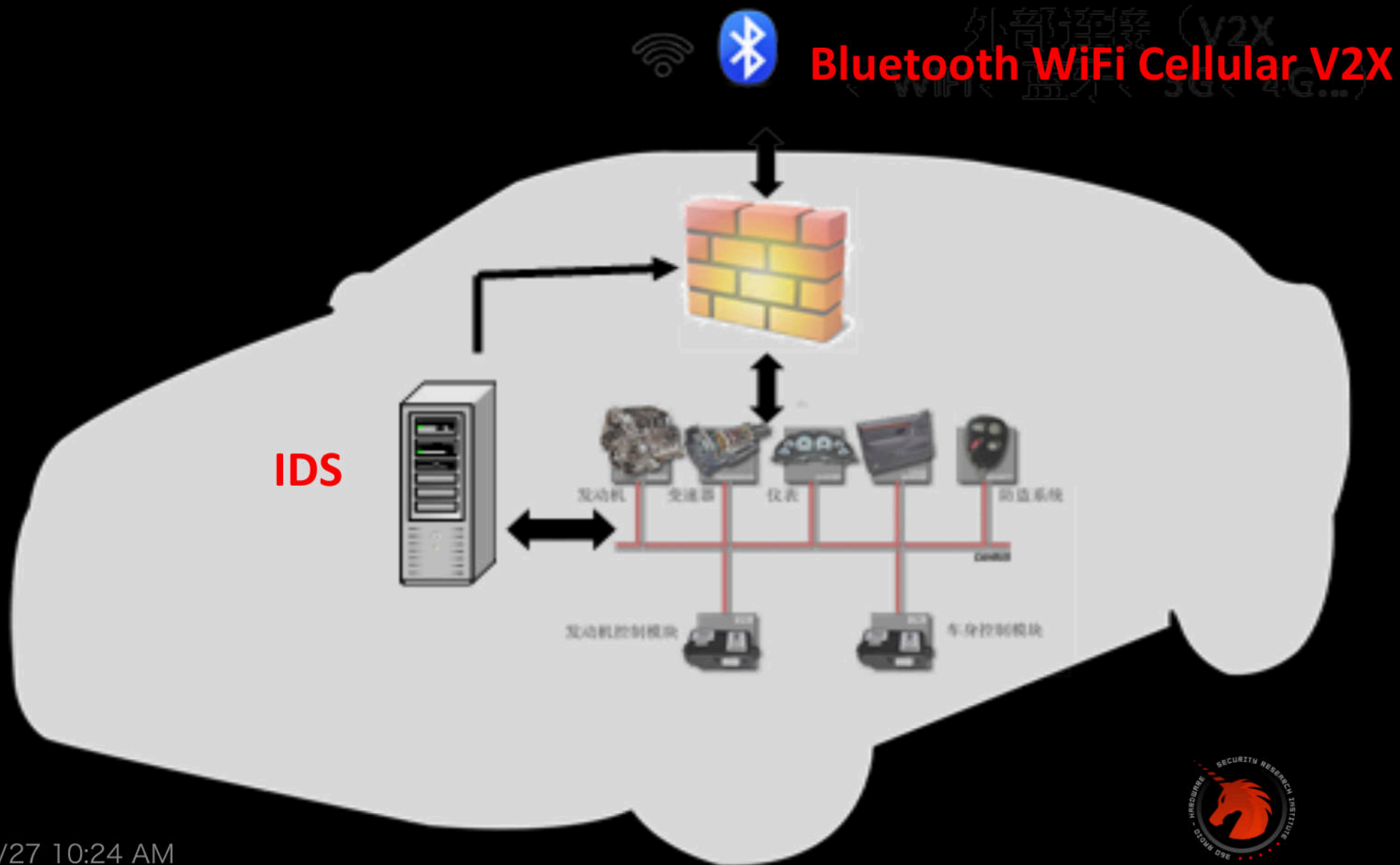
Jeep Uconnect 漏洞



本文提出的架构



安全架构



Entropy-Based Anomaly Detection for In-Vehicle Networks

Michael Müter, Naim Asaj

Daimler AG

Research and Development, GR/PTA

Böblingen, Germany

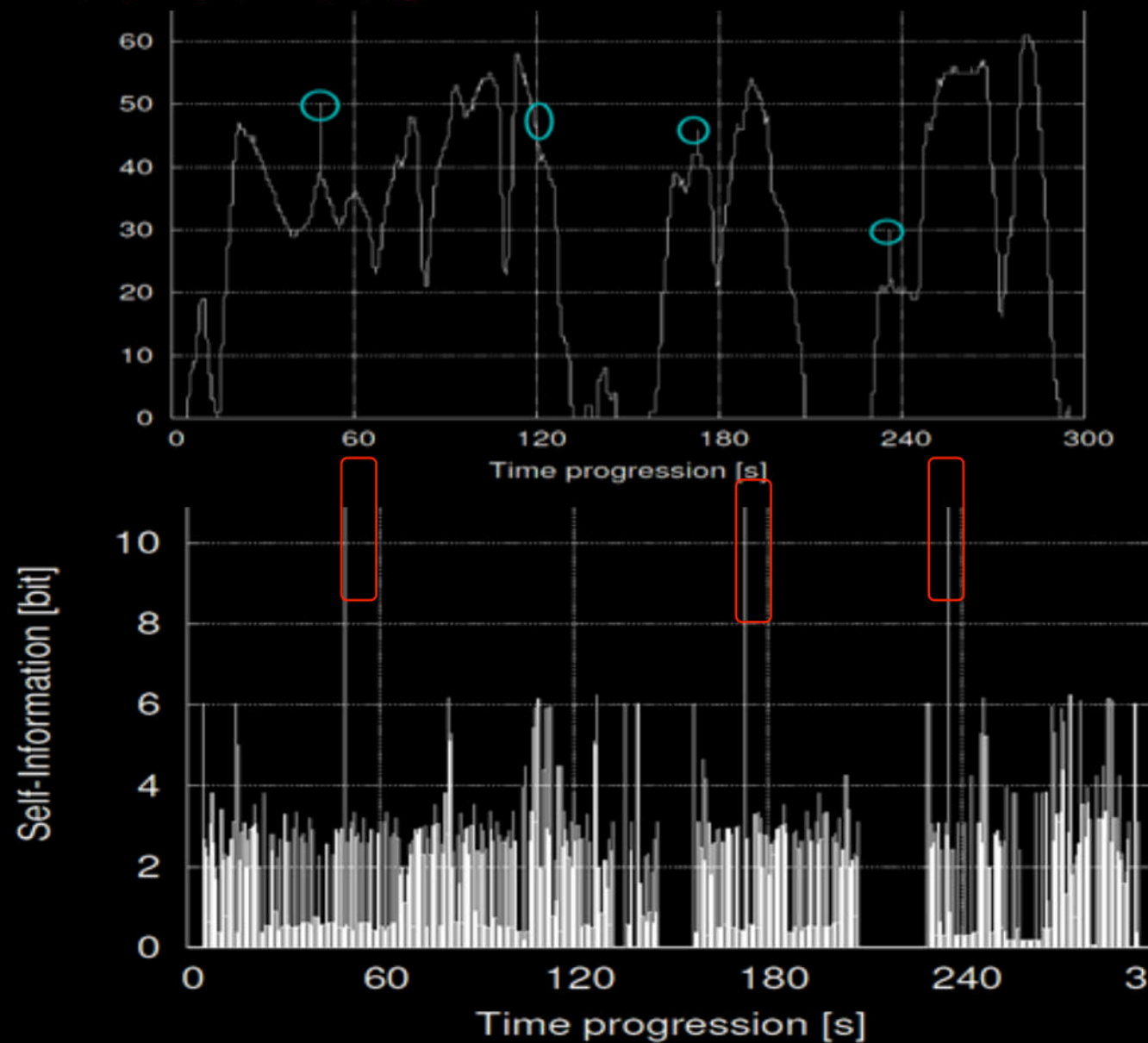
{michael.mueter|naim.asaj}@daimler.com

Abstract—Due to an increased connectivity and seamless integration of information technology into modern vehicles, a trend of research in the automotive domain is the development of holistic IT security concepts. Within the scope of this development, vehicular attack detection is one concept which gains an increased attention, because of its reactive nature that allows to respond to threats during runtime. In this paper we explore the applicability of entropy-based attack detection for in-vehicle networks. We illustrate the crucial aspects for an adaptation of such an approach to the automotive domain. Moreover, we show first exemplary results by applying the approach to measurements derived from a standard vehicle's

protection even when preventive measures failed. Thereby, we show how its self-adapting nature allows an easy adaption to the automotive domain and a convenient extension to new vehicles. We further investigate the main parameters which are crucial for the realization of an information-theoretic intrusion detection concept for the in-vehicle domain. Afterwards, we demonstrate the applicability of our concept by testing it at different attack scenarios on the CAN network of a real vehicle.

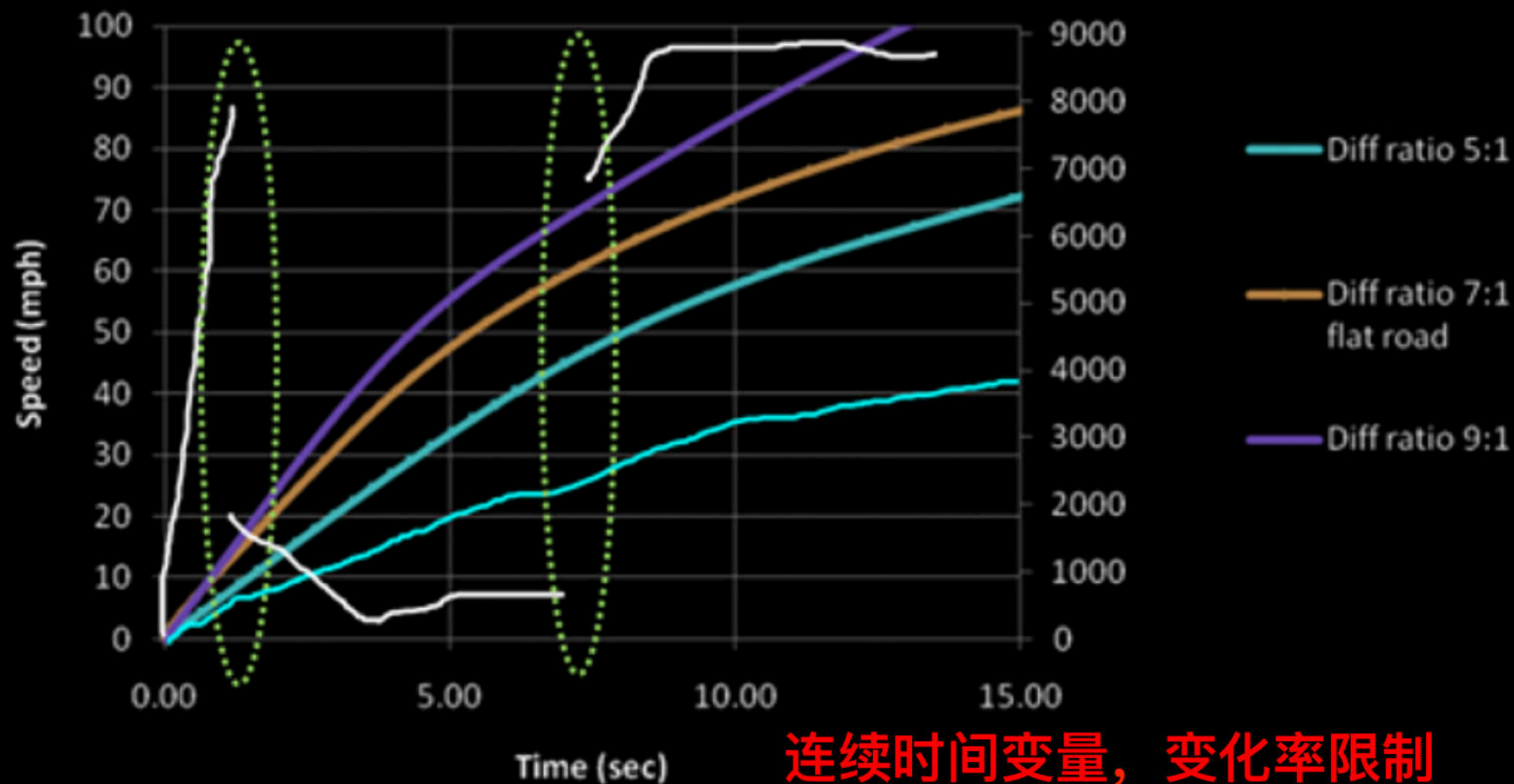


汽车入侵检测相关研究



Not considering
Temporal feature

模型的重要要求（必须能够考虑到时间特征）

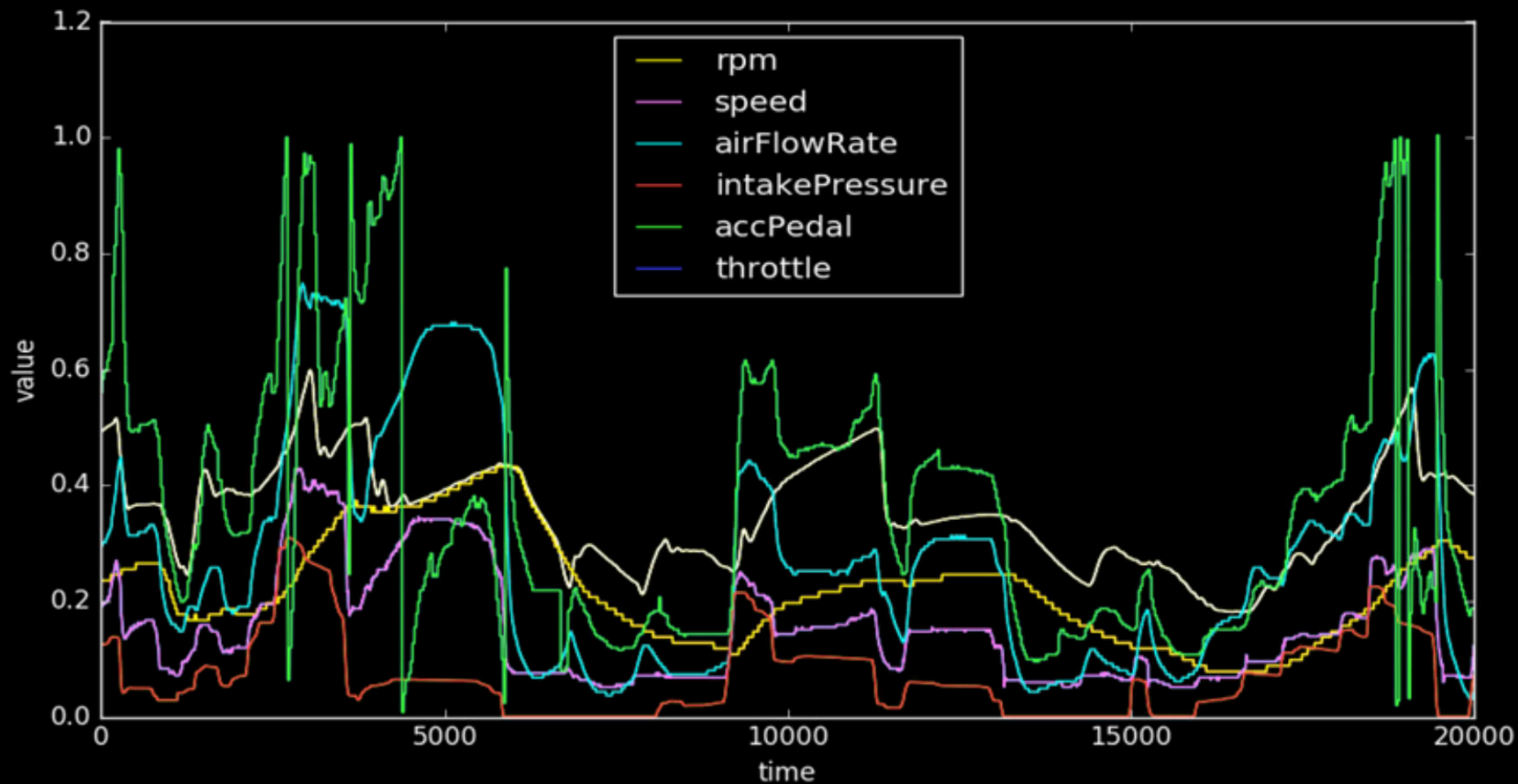


我的方法（建立系统模型）

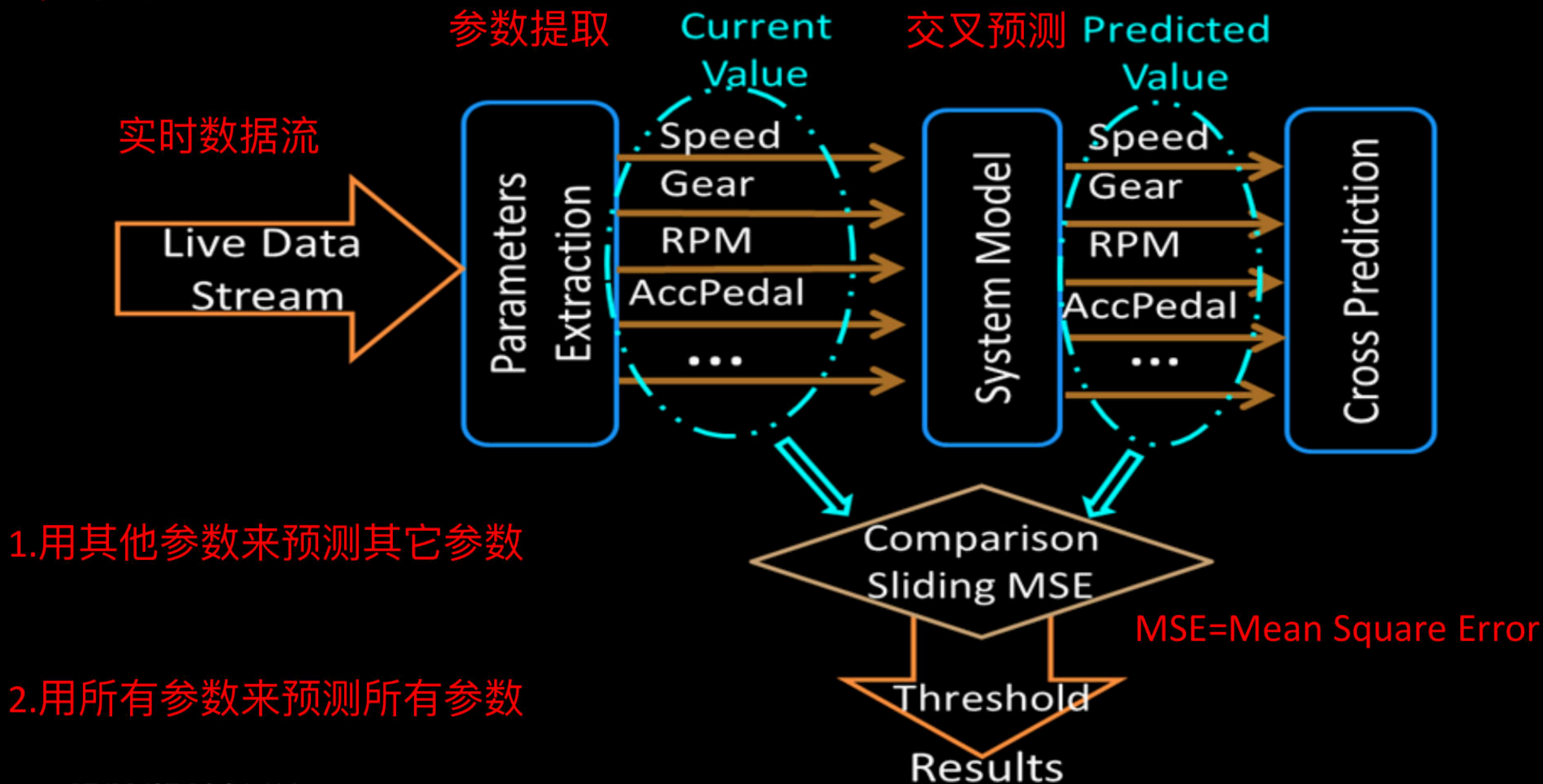

$$\text{Speed} = \text{RPM} * \text{Gear} * C ?$$

C 为常量
离合器 → 非线性

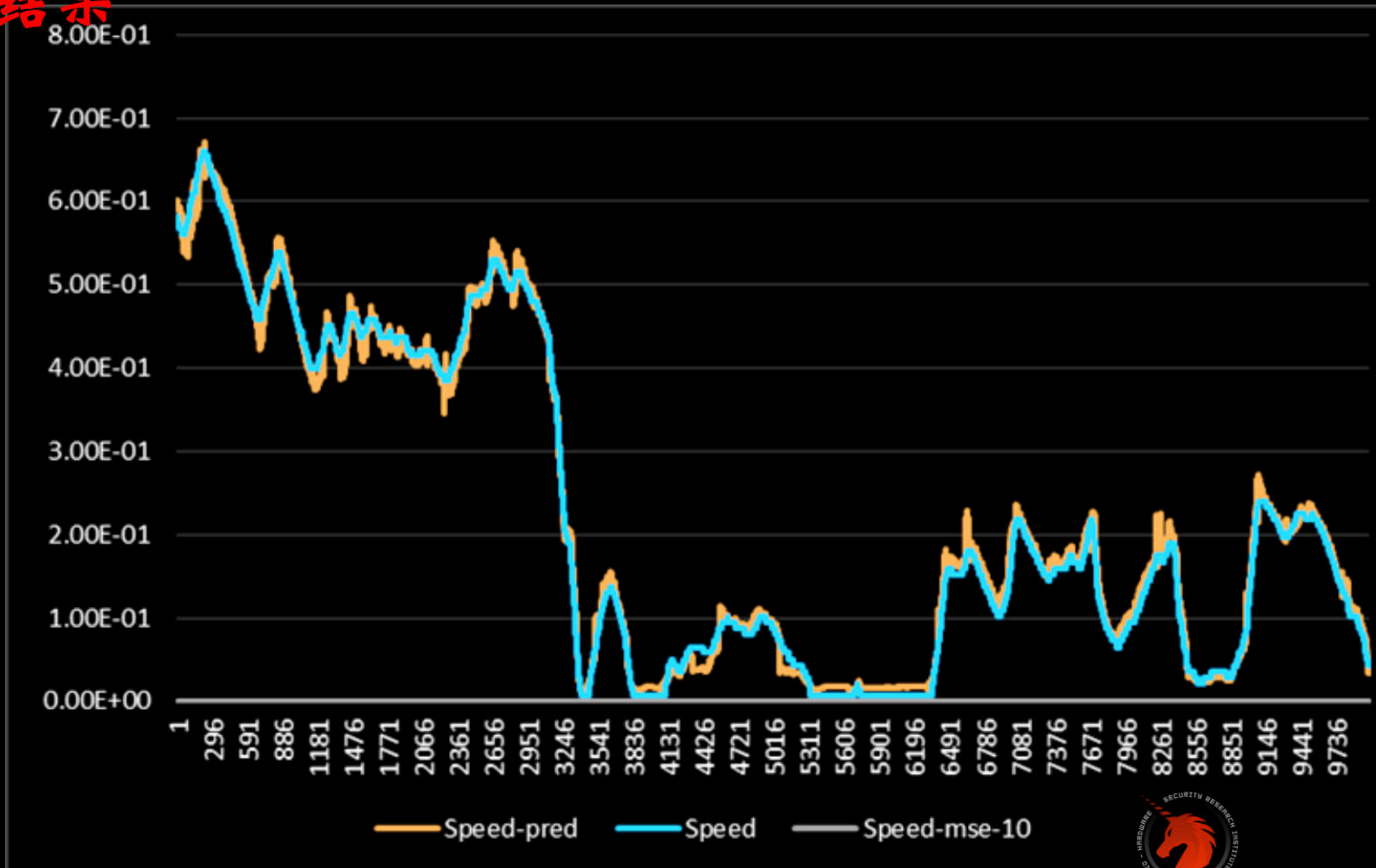
参数的相关性



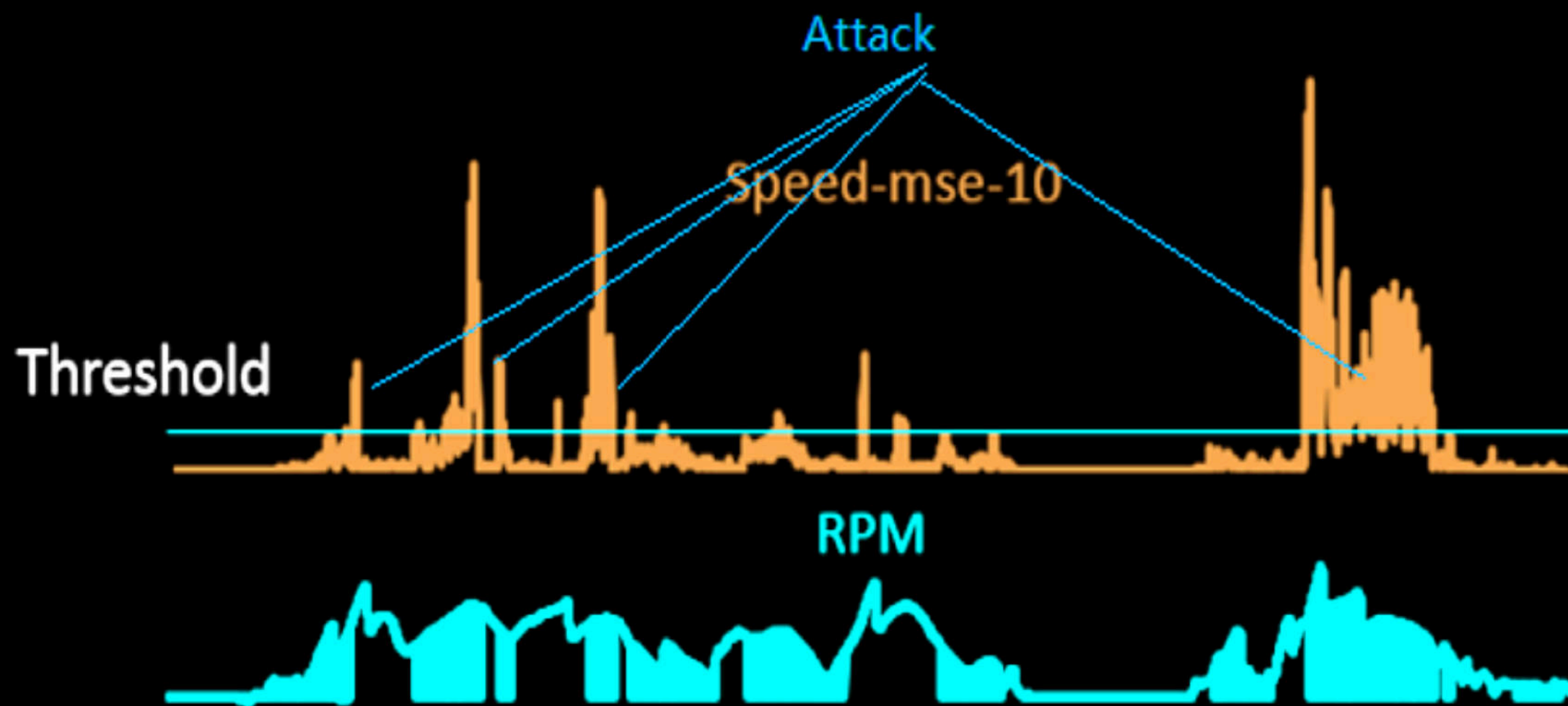
异常检测系统应用

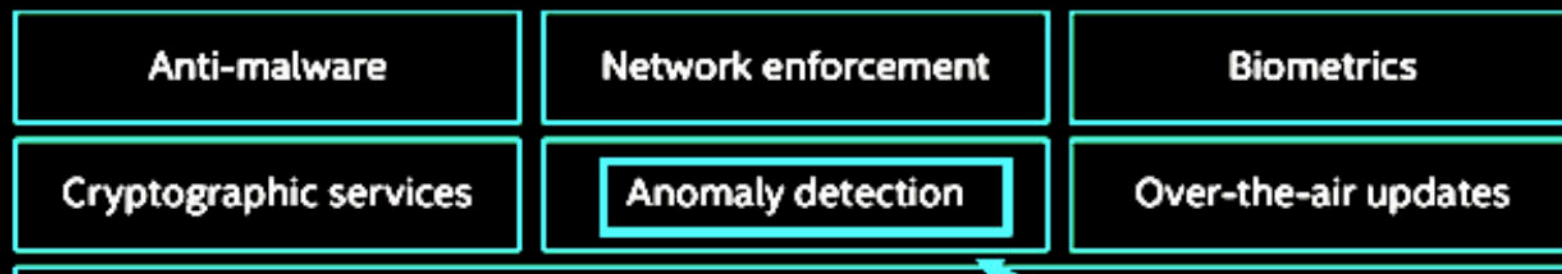


实验结果



模型测试





Owners of computers are painfully familiar with security patches and software update processes. Interrupting a drive for a weekly security scan or urgent update is not realistic. Forcing a patch at the wrong time may be dangerous to the vehicle occupants. Processes will need to be developed to determine when and how to inform the owner that an update is required, how and when to enforce the update, and how to deal with unpatched systems. Memory monitoring and anomaly warning solutions are possible that model the normal operation of the vehicle and create a unique fingerprint. Significant deviation from the model can trigger alerts and even a safe mode with sufficient but diminished functions to enable the car to get home.

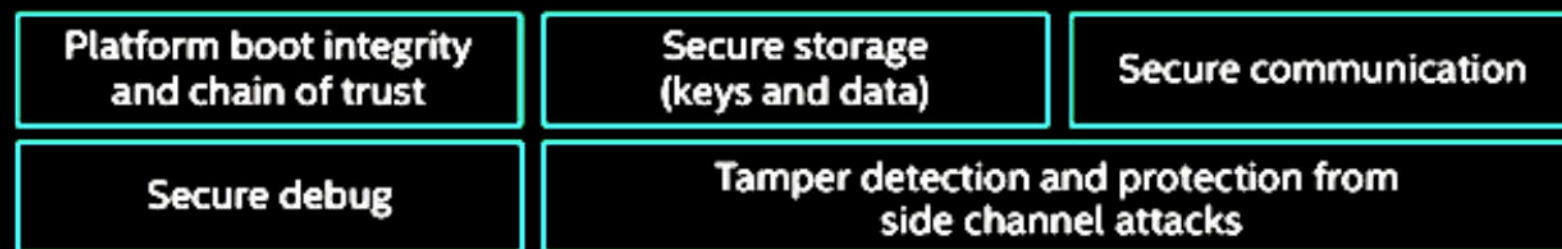
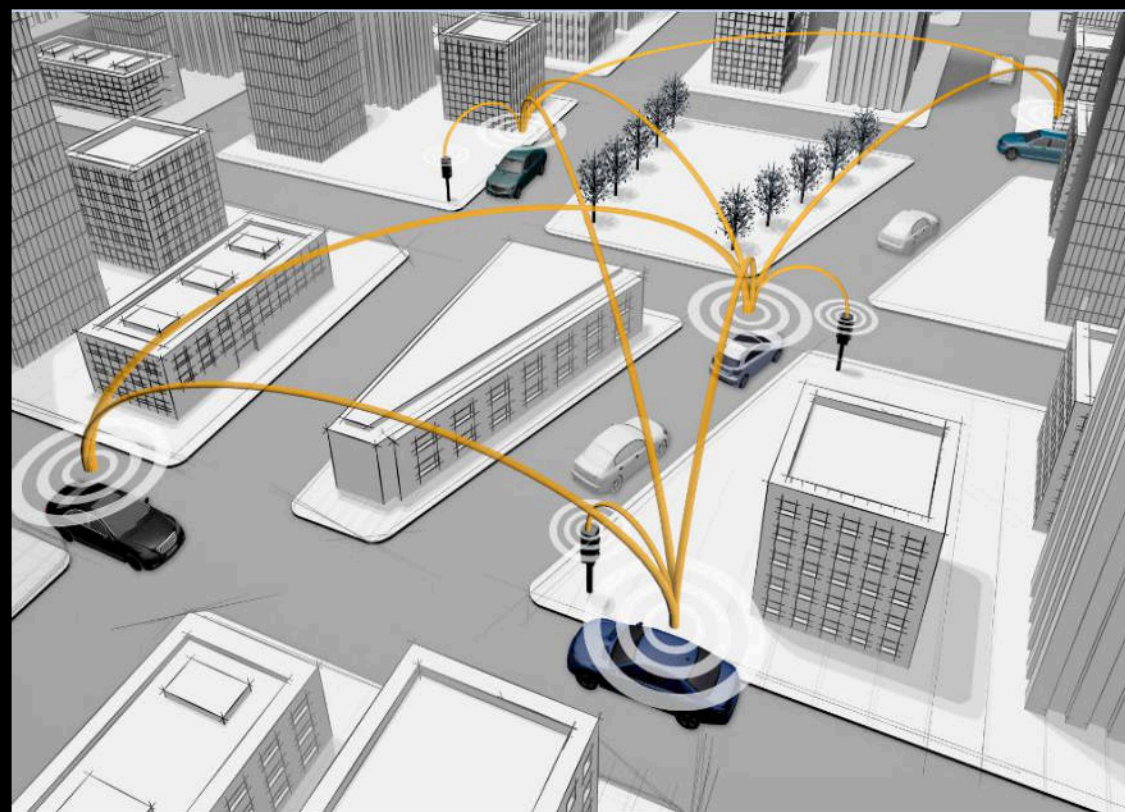


Figure 3. Defense-in-depth building blocks.



V2X安全

首先V2X通信过程中的数据需要能够保证安全性，尽管BSM广播数据里面没有包含可以用于识别个人身份的信息（比如牌照号），但是为了防止攻击者通过伪造或者篡改BSM来扰乱交通造成交通事故，每个条BSM都是经过数字签名的。数字签名就会用到数字证书，而攻击者就是利用这一点来实现对汽车的追踪，已经有案例表明可以通过V2X通信来追踪车辆。有研究者采用伪随机名来对BSM进行签名，伪随机名会每隔一个时间间隔变一次，而这种只能说是一定程度上缓解措施，并不能完全避免被追踪。



[Cars That Think](#) | [Transportation](#) | [Advanced Cars](#)

Researchers Prove Connected Cars Can Be Tracked

By [Mark Harris](#)

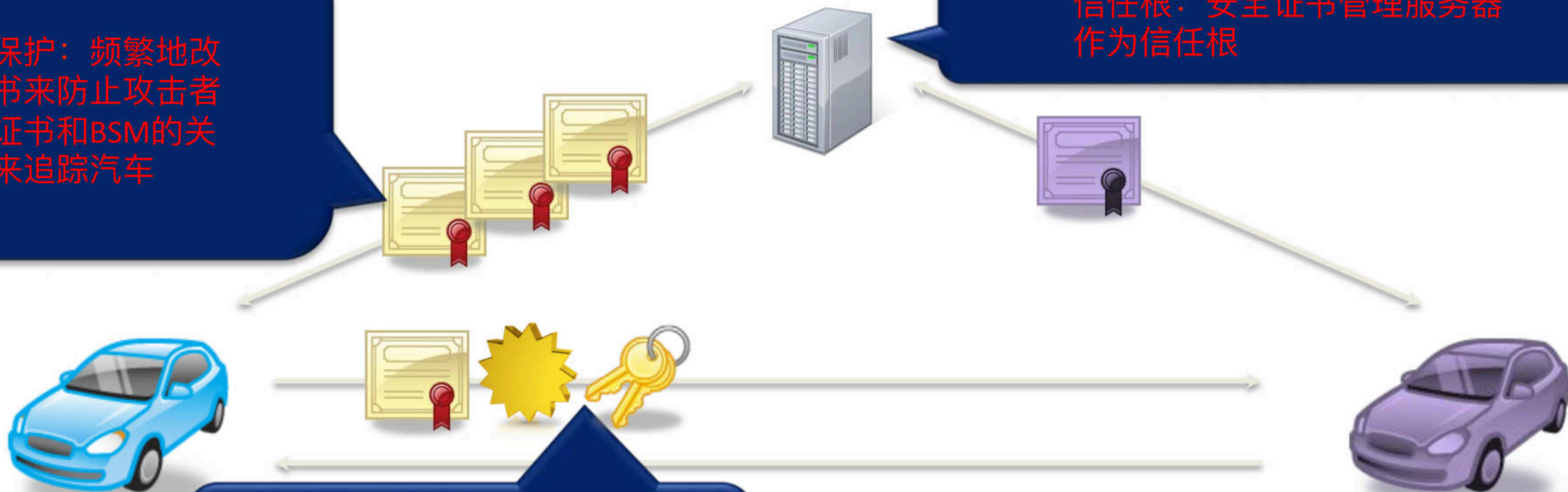
Posted 21 Oct 2015 | 18:00 GMT



surveillance mechanism. It's not yet clear how often connected vehicles will vary the **unique wireless signatures** that identify them, which could limit their use for tracking an individual car. But depending on how long those **"pseudonyms"** remain constant, Petit argues the connected vehicle protocol could offer a new, relatively cheap form of vehicle tracking that could bolster existing law enforcement tracking techniques like [automatic license plate readers](#). Or, he imagines, hackers could collect and crowdsource data from the system to assemble a database of vehicle movements around entire cities.

隐私保护：频繁地改变证书来防止攻击者通过证书和BSM的关联性来追踪汽车

信任根：安全证书管理服务器作为信任根



V2V消息认证：数字签名来保证消息完整性

性能：可以选择只对会引起警告的消息进行验证

